Chloride Exide KE — Battery Finder: Technical Documentation

Version: 2.0 | **Date:** 2026-08-30 | **Stack:** FastAPI · PostgreSQL · React 19 · TypeScript · Tailwind CSS v4

Table of Contents

1. System Overview
2. High-Level System Diagram
3. Backend Architecture
4. Database Schema
5. The Matching Engine — Deep Dive
6. Matching Mode 1: Select Mode
7. Matching Mode 2: Type Mode
8. Authentication & Security
9. Admin Dashboard API
10. Frontend Architecture
11. Data Pipelines
12. Rate Limiting & Observability
13. Performance & Caching Strategy
14. Error Handling & Failure Modes
15. Automated Test Suite
16. Deployment & Environment
17. Operations Runbook
18. Data Quality — History and Current State
19. Glossary
20. Appendix A — Environment Variables
21. Appendix B — Database Table Index
22. Appendix C — Migration History
23. Appendix D — Repository Layout

1. System Overview

The Battery Finder is a production web application that recommends the correct car battery for Kenyan vehicles. Users enter their vehicle details — make, model, year, fuel type, and engine CC — and the system returns a primary battery recommendation with same-technology alternatives. The application is geo-restricted to Kenya, Uganda and Tanzania and is built to serve the Chloride Exide KE brand.

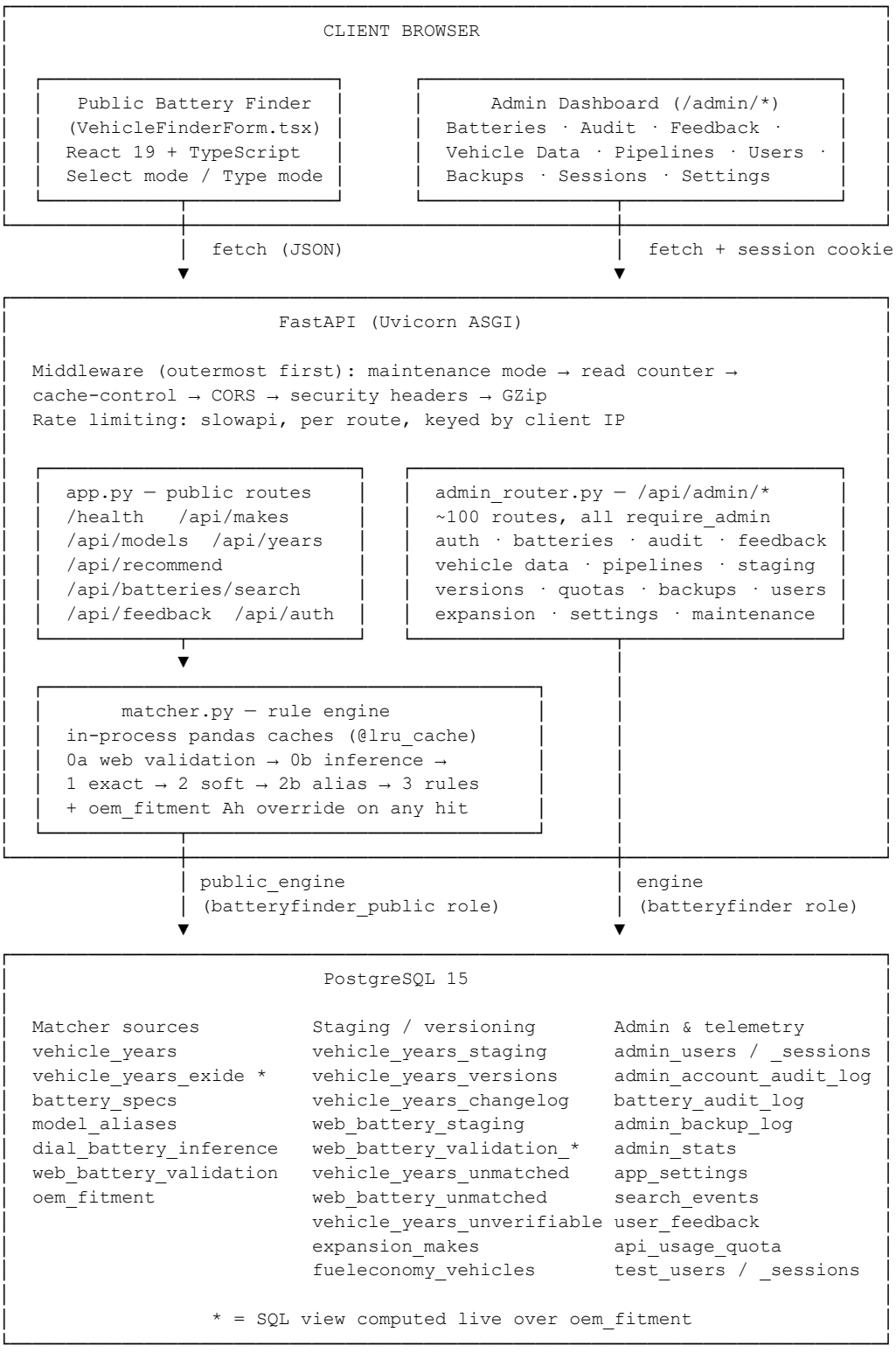
Core technologies:

Layer	Technology
Backend API	Python 3.12, FastAPI, SQLAlchemy 2.0, Alembic, slowapi
Matching	pandas DataFrames, rapidfuzz (fuzzy text matching), rule engine

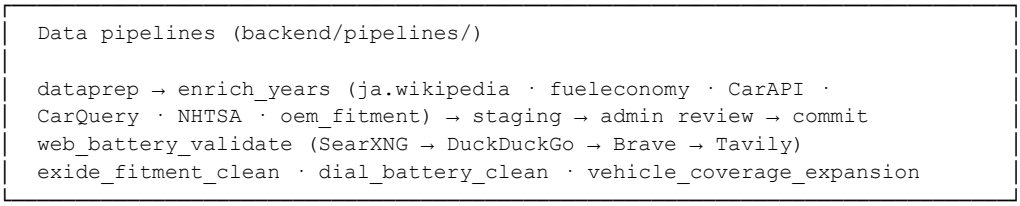
Layer	Technology
Database	PostgreSQL 15 — two roles, two pools (see 8.5); pool size env-tunable
Frontend	React 19, TypeScript, Vite, Tailwind CSS v4, Bun
Auth	bcrypt (cost 12), HttpOnly cookies (admin), Bearer tokens (tests)
Serving	Uvicorn (ASGI); FastAPI serves the built React SPA
Testing	pytest (backend, real Postgres), Vitest (frontend), Jenkins CI

What changed since version 1.0. The recommendation engine gained two new data sources — an internet-sourced fitment table (`web_battery_validation`) and Exide's own OEM fitment guide (`oem_fitment`) — so the matching cascade is now five layers deep with a separate Ah override sitting on top of it (section 5). The database grew from roughly ten tables to twenty-eight plus a view, largely for the staging and versioning workflow that now fronts every bulk data change. The public request path moved onto its own least-privilege Postgres role, and admin accounts became fully self-service (bootstrap, forgot-password, user management) rather than requiring a CLI script on the server.

2. High-Level System Diagram

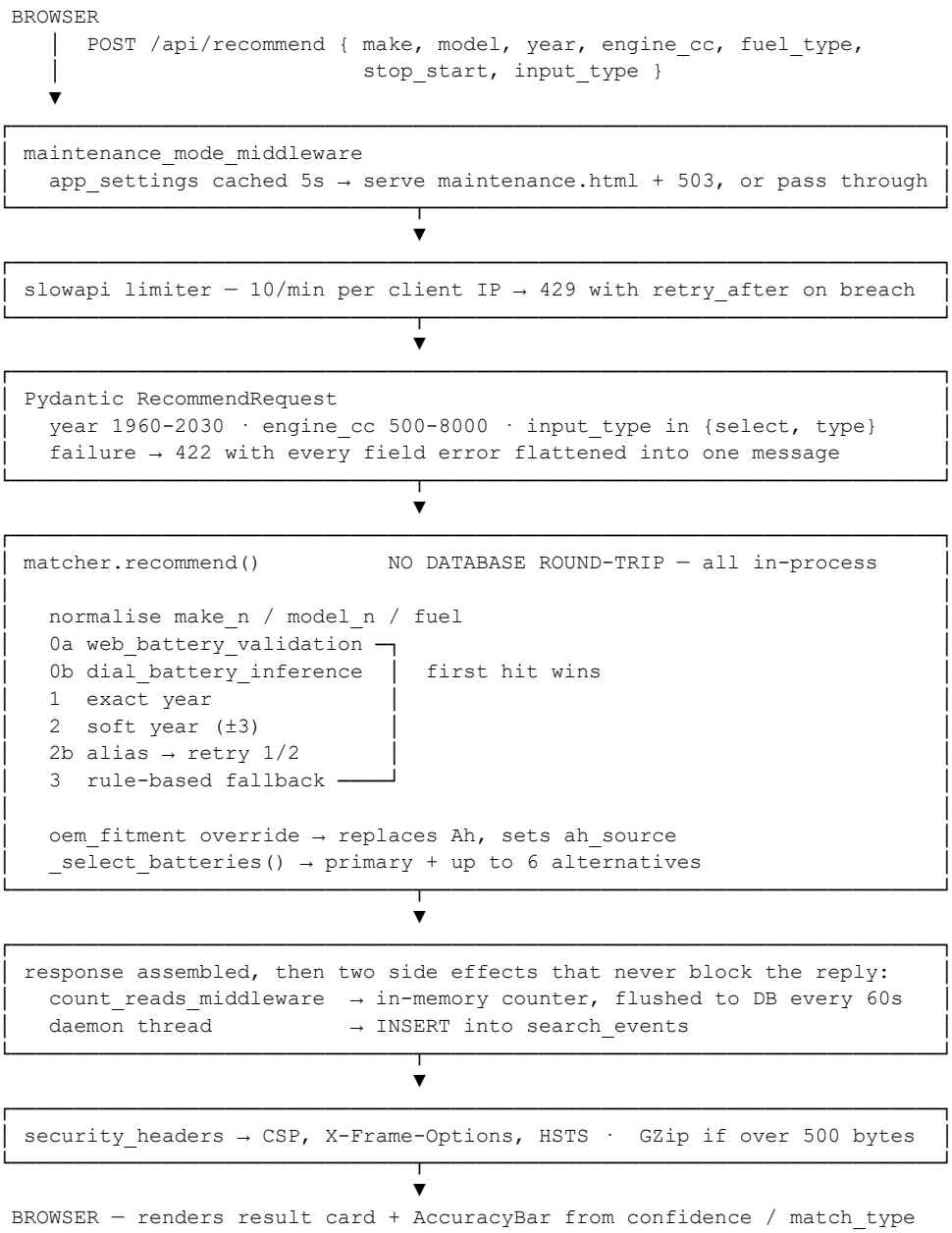


Everything above serves live traffic. The data those tables hold is produced offline by the pipelines below, which an administrator triggers and reviews — they never run as part of a request.



2.1 Request Lifecycle — a single recommendation

The diagram below traces one `POST /api/recommend` from the browser to the response, showing every component it passes through and what each one contributes.



The single most important property here is that the matcher touches no database. Every source table is loaded into a pandas DataFrame at startup and held in an LRU cache, so a recommendation is pure in-process computation.

The only database work in the request path is the two deferred side effects at the end, and neither of them can delay or fail the response.

3. Backend Architecture

3.1 Entry Point: app.py

`app.py` is the FastAPI application root. On startup (via the `lifespan` async context manager) it:

1. Verifies PostgreSQL connectivity with a `SELECT 1`.
2. Warms all five matcher LRU caches (`_vehicles`, `_batteries`, `_model_aliases`, `_inference`, `_fitment`) so the first user request is not cold.
3. Starts a background `threading.Timer` that flushes the in-memory read counter to `admin_stats` every 60 seconds.
4. Schedules a midnight `threading.Timer` that resets the daily read counter to zero.
5. Loads the persisted maintenance-mode flag from the `app_settings` table into the per-process cache.

Public API routes registered in `app.py`:

Method	Path	Rate Limit	Description
GET	`/health`	60/min	Unauthenticated liveness/readiness probe for the load balancer
GET	`/api/makes`	20/min	List all car makes
GET	`/api/models/{make}`	20/min	List models for a given make
GET	`/api/years`	20/min	List years for a make + model
POST	`/api/recommend`	10/min	Get a battery recommendation
GET	`/api/batteries/search`	20/min	Find batteries within ±15% of a target Ah and/or CCA
POST	`/api/feedback`	5/min	Submit feedback on a recommendation
POST	`/api/auth/register`	5/min	Register a test user
POST	`/api/auth/login`	10/min	Log in as a test user
POST	`/api/auth/logout`	—	Log out a test user
GET	`/api/auth/me`	—	Current test user info

`POST /api/recommend` request body:

```
{
  "make":       "TOYOTA",
  "model":      "Corolla",
  "year":       2015,
  "engine_cc":  1500,
  "fuel_type":  "Petrol",
  "stop_start": true,
  "input_type": "select"
}
```

`year` is validated to 1960–2030, `engine_cc` to 500–8000, and `input_type` to `select` or `type`.

`POST /api/recommend` response:

```
{
  "make":            "TOYOTA",
  "model":           "COROLLA",
  "year":            2015,
  "engine_cc":       1500,
  "fuel_type":       "PETROL",
  "battery_region": "NS",
  "recommended_ah": 55,
  "preferred_tech": "EFB",
  "confidence":      100,
  "match_type":      "Exact Match",
  "matched_make":    "TOYOTA",
  "matched_model":  "COROLLA AXIO G",
  "matched_year":    2015,
  "ah_source":       "oem_fitment",
  "primary":         { "battery_code": "...", "ah": 55, "cca_en": 480, ... },
  "alternatives":    [ ... ]
}
```

`ah_source` is new in version 2.0 and records which path actually supplied the Ah figure: `oem_fitment`, `battery_code`, or `cc_bracket_estimate`. See section 5.

3.2 Middleware Stack

Middleware is registered so that maintenance mode runs outermost and GZip innermost:

Middleware	Purpose
`maintenance_mode_middleware`	Serves `static/maintenance.html` with HTTP 503 for every path except `/api/admin/*`, `/admin/*`, `/static/*`, `/assets/*` and `/health`
`count_reads_middleware`	Increments the in-memory read counter for `POST /api/recommend` only
`cache_control_middleware`	Adds `Cache-Control: public, max-age=31536000, immutable` to `/assets/*` (Vite hashes those filenames)
`CORSMiddleware`	Allowlist from `ALLOWED_ORIGINS`; empty by default because the SPA and API are served same-origin
`security_headers`	`X-Content-Type-Options`, `X-Frame-Options: DENY`, `Referrer-Policy`, `Permissions-Policy`, `Content-Security-Policy`, plus `Strict-Transport-Security` when cookies are in secure mode
`GZipMiddleware`	Compresses responses larger than 500 bytes

Two exception handlers are registered: `RequestValidationError` (flattens Pydantic errors into one readable 422 message) and `RateLimitExceeded` (returns a clean 429 with `retry_after` instead of an unhandled 500).

3.3 Read Counter Middleware

Every `POST /api/recommend` request increments `_read_counter_pending` (an in-memory integer guarded by a `threading.Lock`). One timer flushes the accumulated delta to `admin_stats` every 60 seconds in a single write; a second zeroes it at local midnight. This keeps the dashboard's "reads today" figure accurate without adding a database write to the request path.

Separately, each recommendation spawns a short-lived daemon thread that writes a `search_events` row (vehicle asked for, battery returned, match type, confidence, truncated IP, input mode). Failures there are logged at debug level and never surface to the caller.

3.4 Static File Serving & Maintenance Mode

`app.py` mounts:

- `/assets/*` — Vite-built JS/CSS chunks from `frontend/dist/assets/`
- `/static/*` — raw static files (maintenance page, logos)
- `/{full_path}` catch-all — returns React `index.html` for all non-API paths (SPA client-side routing)

The catch-all resolves the requested path with `os.path.normpath()` and serves it only if the result still sits inside the frontend root — the root is compared with a trailing separator so a sibling directory such as `dist-evil` cannot pass as `dist`. Anything that escapes falls through to `index.html`. This closes a path-traversal hole that previously let URL-encoded `../` sequences read arbitrary backend files, including `.env`.

Maintenance mode is **not** an environment variable. It is a row in `app_settings` (`setting_key = 'maintenance_mode'`), toggled from the admin Settings page and cached per process for 5 seconds, so every worker and every instance converges within 5 seconds of a toggle without needing Redis.

4. Database Schema

All migrations are managed by Alembic (in `alembic/versions/`). Run `alembic upgrade head` from `backend/` after pulling. The schema is now 28 tables plus one SQL view, grouped below by role.

4.1 Runtime Tables (read by the matcher)

These seven relations are the only ones the recommendation path touches. All are loaded into memory at startup and re-read only on an explicit cache refresh.

`vehicle_years` — Primary vehicle lookup table. One row per make/model/year combination.

Column	Type	Constraints	Description
id	Integer	PK, autoincrement	
make	String(100)	NOT NULL	Vehicle make, e.g. "TOYOTA"
model	String(200)	NOT NULL	Model/trim as it appears in the source data
year	Integer	NOT NULL	Model year
engine_capacity	Integer	nullable	Engine displacement in CC
fuel	String(50)	nullable	Raw fuel string, normalised at load time
source	String(50)	nullable	Which enrichment source produced the row
model_number	String(100)	nullable	CRSP chassis/type-approval code, e.g. "3BA-VJA300W-GNUZZ"

Unique constraint: `(make, model, year)`. Indexes on `make` and `(make, model)`. `source` and `model_number` were added so every row carries its provenance — historically 98% of rows had no source recorded, which made bad year data impossible to attribute.

`vehicle_years_exide` — **A SQL view, not a table.** It expands `oem_fitment`'s year ranges into one row per make/model/year, strips trailing chassis codes from the model string, and caps every range at the current year. `matcher._vehicles()` reads `vehicle_years UNION ALL vehicle_years_exide`, so Exide's fitment-guide

vehicles are searchable without ever being written into `vehicle_years`. Because it is a view, it updates the moment `oem_fitment` changes — there is no separate refresh step.

`battery_specs` — Battery catalogue. One row per battery SKU.

Column	Type	Constraints	Description
id	Integer	PK	
battery_code	String(100)	NOT NULL, unique	SKU code
model_key	String(100)	NOT NULL	Standard prefix — "DIN…" means DIN, anything else NS
ah	Float	nullable	Ampere-hours
cca_en	Float	nullable	Cold cranking amps (EN rating)
technology	String(100)	nullable	EFB / AGM / MF / SB (Flooded)
origin	String(50)	nullable	`local` or `imported`
brand	String(100)	nullable	e.g. Powerlast, Sebang
deleted_at	DateTime(tz)	nullable	Soft delete — always filter `IS NULL`

Indexes on `model_key` and `ah`.

`model_aliases` — International → JDM model name mappings, with a `priority` column (lower wins) used to break ties when one international name maps to several JDM nameplates.

`dial_battery_inference` — Real-world call-centre order data: which battery was actually sold, per vehicle type and model, with a `frequency` count and `last_sale_date` tiebreaker.

`web_battery_validation` — Internet-sourced fitment, one row per `(make_n, model_n, year)` with `battery_code`, `ah`, `technology`, `source` and `validated_at`. Populated offline by `pipelines/web_battery_validate.py`. Unique on `(make_n, model_n, year)`; indexed on `make_n` and `(make_n, model_n)`.

`oem_fitment` — Exide's official global fitment guide, kept as year ranges rather than exploded rows.

Column	Type	Description
vehicle_category	String(20)	`passenger` or `commercial`
make / model	String	Model is the raw trim string, e.g. "OUTLANDER III 2.2 DI-D"
year_from / year_to	Integer	`year_to` NULL means open-ended
ah	Float	Fitment Ah — this is what overrides the matcher's own figure
technology	String(50)	Cleaned value; `raw_technology` keeps the original
dimensions	String(50)	Raw, e.g. "242*175*190"
cylinder_capacity_cc	Integer	Parsed from strings like "1368cm"
source_row	Integer	Original Excel row, for debugging

A single make/model/year-range legitimately has **several** rows — Exide lists multiple battery tiers for the same trim (a base 50Ah/MF option alongside 55Ah/EFB and 60Ah/EFB upgrades). That is not duplicate data, and the override logic in section 5 picks among the tiers deliberately.

4.2 Pipeline, Staging & Versioning Tables

Every bulk data change now goes through staging and is revertible.

Table	Purpose
`vehicles_raw`	Output of Stage 1 (`dataprep.py`) — deduplicated make/model/CC/fuel rows from the CRSP Excel
`vehicle_years_staging`	Stage 2 output awaiting review. Carries `is_valid`, `invalid_reason`, `conflict` and `conflict_detail` (JSON showing current vs staged)
`vehicle_years_versions`	One row per commit: counts of added/updated/removed/conflicting rows, who initiated and who committed
`vehicle_years_changelog`	Row-level diffs per version (`added` / `updated` / `removed` with old and new JSON values) — this is what makes a revert possible
`vehicle_years_unmatched`	Make/model pairs no source could resolve in a given run
`vehicle_years_unverifiable`	Rows quarantined out of `vehicle_years` because their years could not be verified; keeps `base_model`, `reason` and a `batch_id` so a run can be restored
`web_battery_staging`	Same review workflow for the web-validation pipeline
`web_battery_validation_versions` / `_changelog`	Version history and row-level diffs for web-validation commits
`web_battery_unmatched`	Web-validation rows rejected as implausible, with both the web's Ah and the rules' expected Ah for comparison
`pipeline_run_log`	Per-run bookkeeping
`expansion_makes`	Target makes for the coverage-expansion pipeline, with per-source slugs and a `year_tier` (default / commercial / chinese)
`fueleconomy_vehicles`	Cached fueleconomy.gov bulk CSV, loaded into the DB rather than re-parsed per run
`enrichment_cache_meta`	Freshness metadata per cached dataset — drives the "cache is stale" prompt in the admin UI
`api_usage_quota`	Per-provider call accounting. `quota_limit = -1` means unlimited; a NULL `period_end` marks a prepaid one-time balance that never auto-resets

4.3 Admin & Audit Tables

Table	Purpose
`admin_users`	bcrypt credentials plus `failed_login_attempts`, `locked_until`, `email`, and a SHA-256 `reset_token_hash` with its expiry
`admin_sessions`	One row per active admin login, 8-hour TTL, 64-char hex token
`admin_account_audit_log`	Bootstrap / create / delete / reset-link / password-reset events. Actor and target usernames are stored as snapshots, not just foreign keys, so entries stay readable after an account is deleted
`battery_audit_log`	Immutable change history for `battery_specs`, old and new values as JSON
`admin_backup_log`	One row per backup attempt: filename, size, status, error detail, who triggered it

Table	Purpose
admin_stats	Key-value counters; currently db_reads
app_settings	Key-value application settings; currently maintenance_mode
search_events	One row per recommendation: vehicle asked for, battery returned, match type, confidence, whether it matched, truncated IP, and input mode

4.4 User Tables

Table	Purpose
user_feedback	Satisfaction (1–5), accuracy rating, which parts were wrong (JSON), comments, plus the match metadata the recommendation returned
test_users	Registered test-user accounts (bcrypt)
test_user_sessions	Bearer-token sessions, 24-hour TTL, with last_seen_at

5. The Matching Engine — Deep Dive

matcher.py is the recommendation core. It runs entirely in-process against pandas DataFrames held in LRU caches. No database round-trip happens during a recommendation request.

5.1 Data Loading & Caching

At startup, app.py warms five caches; two more load lazily on first use:

```
matcher._vehicles()       → vehicle_years UNION ALL vehicle_years_exide
matcher._batteries()      → battery_specs WHERE deleted_at IS NULL
matcher._model_aliases()  → model_aliases
matcher._inference()      → dial_battery_inference
matcher._fitment()        → oem_fitment
matcher._web_validation() → web_battery_validation      (lazy)
matcher._make_index(make) → per-make row slice + model → years map (lazy, 128 makes)
```

Each is decorated with @lru_cache. All read through public_engine — the least-privilege role (section 8.5). The caches are cleared and immediately re-warmed whenever an admin edits battery specs or triggers POST /api/admin/cache/refresh.

_make_index() deserves a note: it precomputes, once per make, the make-scoped row slice and a model_n → sorted years map. Before it existed, both recommend() and the per-candidate year filtering inside fuzzy matching re-scanned the full vehicle table on every call.

Normalised columns added at load time:

- make_n — uppercase + strip + collapse whitespace
- model_n — result of _norm_model_key(): uppercase, hyphens → space, and a space inserted at every letter↔digit boundary, so CX5, CX 5 and CX-5 all resolve to the same key
- fuel_n — mapped through _FUEL_MAP, which folds vendor spellings and source-data typos ("DEISEL" → DIESEL, "ELECCTRIC" → EV, "PLUG-IN HYBRID" → HYBRID)
- vtype_n, vmodel_n, bcode_n — the same normalisation applied to the inference table

5.2 The recommend() Function — Layer Order

```
recommend(make, model, year, engine_cc, fuel_type, stop_start) → dict
```

Pre-processing:

1. Normalise `make_n` = `make.upper().strip()`
2. Normalise `model_n` = `_norm_model_key(model)`
3. Set defaults: `resolved_cc = engine_cc or 1500`, `resolved_fuel = _norm_fuel(fuel_type)`
4. Set `confidence = 40`, `match_type = "Estimated (Rule-Based)"` as the floor

The engine then tries layers in order and **returns at the first successful match**:

Layer	Source	Confidence	`match_type`
0a	`web_battery_validation` — internet-sourced, year-specific	75–90	Web-Validated Match
0b	`dial_battery_inference` — real call-centre sales	80–95	Real-World Data Match
1	`vehicle_years` — fuzzy model ≥ 90 + exact year	100	Exact Match
2	`vehicle_years` — fuzzy model + year within ±3	60–89	Close Match
2b	`model_aliases` — international → JDM, then re-run 1/2	60–100	Exact / Close Match
3	Rules — engine CC + fuel → Ah bracket	40	Estimated (Rule-Based)

Layers 0a and 0b take priority over 1–3 because they reflect actual fitment outcomes rather than a rule-of-thumb estimate. They only fire when a matching row exists in their source table, so most searches still fall through to layers 1–3.

On top of all of this sits the OEM fitment override (described after Layer 3). It is not a competing layer: it never changes which layer matched or the resulting confidence, only the Ah figure that layer produces.

Layer 0a: Web-Validated Match

What it does: Looks up `web_battery_validation` for this exact `(make, model, year)`. The table is populated offline by `pipelines/web_battery_validate.py`, which searches the open web for the battery commonly fitted to each vehicle.

How it works:

1. Filter to rows where `make_n` matches, then to rows where `year` matches exactly. A miss on either ends the layer — unlike inference, this source is year-specific and is never stretched across years.
2. Exact `model_n` hit → confidence 90. Otherwise fuzzy match with `token_set_ratio ≥ 85` → confidence 75.
3. Engine CC and fuel are then resolved from `vehicle_years` for reporting only — exact year first, else the nearest row within ±3 years.
4. The stored `battery_code` is looked up in `battery_specs` to yield `(target_ah, technology)`.
5. Technology is decided the same way as Layer 0b (below): a luxury make past its AGM year always gets AGM; `stop_start=False` recomputes from rules; AGM/EFB in the source is honoured; MF is recomputed for stop-start vehicles.

Why it outranks inference: web validation reflects current fitment standards, while inference reflects historical sales — including sales that were themselves wrong recommendations.

Layer 0b: Inference Match (Real-World Order Data)

What it does: Looks up `dial_battery_inference`. This table contains actual Dial-A-Battery call-centre sales data — if a battery was sold for a Toyota Corolla 100 times, that is strong evidence.

How it works:

1. Filter inference rows where `vtype_n == make_n`.
2. Exact `model_n` hit → confidence 95; else fuzzy `token_set_ratio ≥ 85` → confidence 80.
3. Among all rows for the matched (make, model), pick the battery with the **highest frequency**, tie-broken by the most recent `last_sale_date`.
4. Look up that battery code in `battery_specs` (exact → fuzzy → legacy parser) to get `(target_ah, technology)`.
5. **Technology override logic:**

- Luxury make at or past its AGM adoption year → AGM regardless of anything else.
- `stop_start=False` → recompute from rules (yields MF).
- Source returned AGM or EFB → honour it; a call centre upgrading the chemistry was a deliberate decision.
- Source returned MF and `stop_start=True` → recompute via `_preferred_tech()`. MF codes in the inference table often reflect non-i-stop sales or outright wrong recommendations, so they are not copied blindly onto stop-start vehicles.

1. Call `_select_batteries(target_ah, pref_tech, region)` and return.

Return confidence: 80 (fuzzy model match) or 95 (exact model match). `match_type = "Real-World Data Match"`. The frontend `AccuracyBar` awards full scores for both Car Found and Data Quality segments when this layer fires.

Layer 1: Exact Match

Reached only if neither Layer 0 source hit.

Step 1 — Make resolution: Filter the vehicle table to rows where `make_n` matches. If no rows are found, fuzzy-match the make against all known makes with `fuzz.WRatio ≥ 75`.

Step 2 — Model fuzzy match (`_fuzzy_model_score_for_year`): This function is the core of input-to-database matching. An exact `model_n` hit short-circuits it entirely with score 100 — this matters because a longer trim variant can otherwise tie at 100 and win. Otherwise three scorers run in order:

```
1. fuzz.partial_ratio    (threshold ≥ 80, only if len(query) ≥ 4)
   — catches prefix inputs: "COROLLA" matches "COROLLA AXIO G"

2. fuzz.token_set_ratio  (threshold ≥ 72)
   — catches variant-token inputs: "MARCH ACTIVE" matches "MARCH G"
   — ignores word order and extra tokens

3. fuzz.WRatio           (threshold ≥ 60)
   — general-purpose weighted ratio fallback
```

For each scorer, rather than taking the top-scoring candidate, it collects **all** candidates above the threshold and picks the best with a multi-key sort:

```
Priority key: (starts_with_query, is_exact_year, -year_delta, score, model_n)
```

`starts_with_query` is 1 when the candidate model name starts with the user's input. This stops "FIT" from being hijacked by a longer "FIT SPORT" when "FIT SHUTTLE" — whose years actually cover the requested year — also scores 100.

Step 3a — Exact year match: Filter the matched model's rows for `year == year`. If found:

- `confidence = 100` if model_score ≥ 90, else `int(model_score)`
- `match_type = "Exact Match"` if model_score ≥ 90, else `"Close Match"`
- `resolved_cc` and `resolved_fuel` are taken from this row — on a dataset match the dataset is authoritative.
- AccuracyBar: Car Found fills to 50/50; Year fills to 25/25 (zero delta).

Layer 2: Soft Year Match

Reached if no exact year row exists for the matched model.

Step 3b — ±3 year window: Filter the matched model's rows to `year ∈ [year-3, year+3]` and pick the closest year.

```
year_delta  = |nearest["year"] - requested_year|
confidence  = max(60, int(model_score) - year_delta * 3)
match_type  = "Close Match"
```

Example: model score 85, year delta 2 → `confidence = max(60, 85 - 6) = 79`.

AccuracyBar Year segment: delta 0 → 25 pts, delta 1 → 20, delta 2 → 13, delta 3 → 8. Car Found fills proportionally to the model score (20–40 out of 50 pts in close-match range).

Layer 2b: Alias Resolution (runs after Layer 2 fails)

If nothing matched at all (`matched_year is None`) and `enable_aliases=True`, the engine tries international → JDM model aliases:

1. Filter `model_aliases` to the current make.
2. Fuzzy-match `model_n` against `intl_model_n` values with `fuzz.WRatio ≥ 75`.
3. For each matching alias, resolve its `jdm_model_n` values against the vehicle dataset, again at `WRatio ≥ 75`.
4. From all resolved candidates, pick the best by: exact year first, then smallest year delta, then lowest alias `priority`, then highest JDM similarity.
5. Re-run Steps 3a/3b with the resolved JDM model name.

This is how a user typing "COROLLA" reaches "COROLLA AXIO G" or "COROLLA FIELDER" — the alias table maps one international name to several JDM trims, and the engine picks the one whose year range best covers the requested year.

Layer 3: Rule-Based Fallback

Reached if every matching layer failed; confidence stays at 40. AccuracyBar: Car Found = 0, Data Quality = 4 (minimum), Engine Info proportional to whether the CC was non-default. An amber warning banner is shown above the result card when this layer fires (`matched_make` is `null` in the response).

`_target_ah(engine_cc, fuel, year)` — Ah bracket lookup table:

Max CC (inclusive)	Petrol Ah	Diesel Ah	Hybrid Ah
1000	35	40	35
1600	45	50	45
2000	55	65	55
2500	70	80	65
3000	80	90	80

Max CC (inclusive)	Petrol Ah	Diesel Ah	Hybrid Ah
4000	90	100	90
9999+	100	120	100

EVs bypass the table entirely and take a 45 Ah base: the 12V auxiliary battery in an electric vehicle is not correlated with traction-motor size.

Year modifier (only applied in rule-based mode):

Year range	Modifier	Rationale
≥ 2018	+10 Ah	Modern electronics era
2012–2017	+5 Ah	Early ADAS era
2000–2011	0	
< 2000	-5 Ah	Pre-OBD2, minimal electrical load

A guard also rewrites `HYBRID` to `PETROL` when the matched year is before 2000, since pre-2000 hybrid labels in the source data are always errors.

`_preferred_tech(engine_cc, fuel, year, make, stop_start)` — Technology selection, first match wins:

Condition	Technology
EV fuel type	MF
Luxury/premium make **at or past its AGM adoption year**	AGM
Hybrid fuel type	EFB
`stop_start=True` AND (Diesel OR engine_cc ≥ 2500)	AGM
`stop_start=True` (standard petrol)	EFB
`stop_start=False`	MF

The luxury-AGM rule is year-gated, which is new in version 2.0. AGM did not become an OEM fitment on premium cars until stop-start and brake-energy regeneration arrived, so recommending AGM for a 2001 320i both overcharges the customer and misstates the fitment. A per-make adoption table is used rather than one industry-wide date — BMW was fitting AGM in 2007, Maserati not until 2013:

Make	AGM from	Make	AGM from
BMW	2007	Jaguar	2011
Mercedes / Mercedes-Benz	2008	Land Rover	2011
Audi	2010	Bentley	2012
Porsche	2010	Lexus	2012
Volvo	2010	Infiniti	2013
Cadillac	2010	Maserati	2013
Rolls-Royce	2010	*(any other premium make)*	2010
Ferrari	2010		

These are brand-level adoption dates, not per-model fitment facts; they are deliberately set at the point the technology became normal for the brand rather than its first appearance anywhere in the range. Where Exide's own fitment guide covers a vehicle, that data wins — see the override below.

Battery region detection (`_make_region`):

Region	Makes
NS	Toyota, Honda, Nissan, Mazda, Subaru, Isuzu, Hino, Lexus, Daihatsu, Suzuki, Mitsubishi (incl. Fuso), UD, Hyundai, Kia, and the Chinese makes (Chery, Dongfeng, FAW, Foton, Great Wall, Haval, SAIC)
DIN	Everything else — European, American and Indian makes (Audi, BMW, Mercedes, VW, Ford, Chevrolet, Peugeot, Renault, Fiat, Tata, Scania, MAN, …)

This determines whether the `battery_specs` pool is filtered to NS-standard or DIN-standard batteries, detected from the `Model Key` prefix: "DIN…" → DIN, everything else → NS. The region always comes from the vehicle's own make, never from a scraped keyword — trusting a scraped "NS"/"DIN" string previously put DIN-coded batteries on 490 NS-region vehicles.

OEM Fitment Override

Once any layer above has resolved a `(make, model, year)`, `oem_fitment` is consulted for that same vehicle. If a row covers it, **its Ah replaces whatever the layer would otherwise have used** — including a confirmed battery-code Ah from Layer 0a or 0b — because this is Exide's own spec sheet. The response's `ah_source` field records which path actually supplied the figure: `oem_fitment`, `battery_code`, or `cc_bracket_estimate`.

Matching is exact model first, then fuzzy `token_set_ratio ≥ 85`, always constrained to rows whose `[year_from, year_to]` covers the year (a NULL `year_to` is open-ended). Rows with a NULL Ah are skipped — a technology-only hint is not enough to drive battery selection.

Two details matter:

- **Ties are pooled, not picked arbitrarily.** A bare query like "OUTLANDER" is a subset match scoring 100 against many different Exide trims at once. Rather than take whichever one the fuzzy matcher returns first, every model tied at the best score is collected, so the choice is made deliberately in the next step instead of landing on an unrepresentative trim such as the hybrid's 45 Ah.
- **Among tied candidates, the tier whose technology matches the already-decided `preferred_tech` wins**, falling back to highest Ah only when none match. This keeps the Ah figure paired with a chemistry Exide actually offered it at.

`oem_fitment`'s technology column is deliberately NOT applied to `preferred_tech`. Many of its values are Exide product-tier names (PREMIUM, CLASSIC, START PRO) rather than chemistries, and even where the value is a real chemistry, technology preference must keep following this application's own luxury-make and stop-start rules, which know about local stock and brand-tier policy in a way a global guide does not.

Battery Selection (_select_batteries)

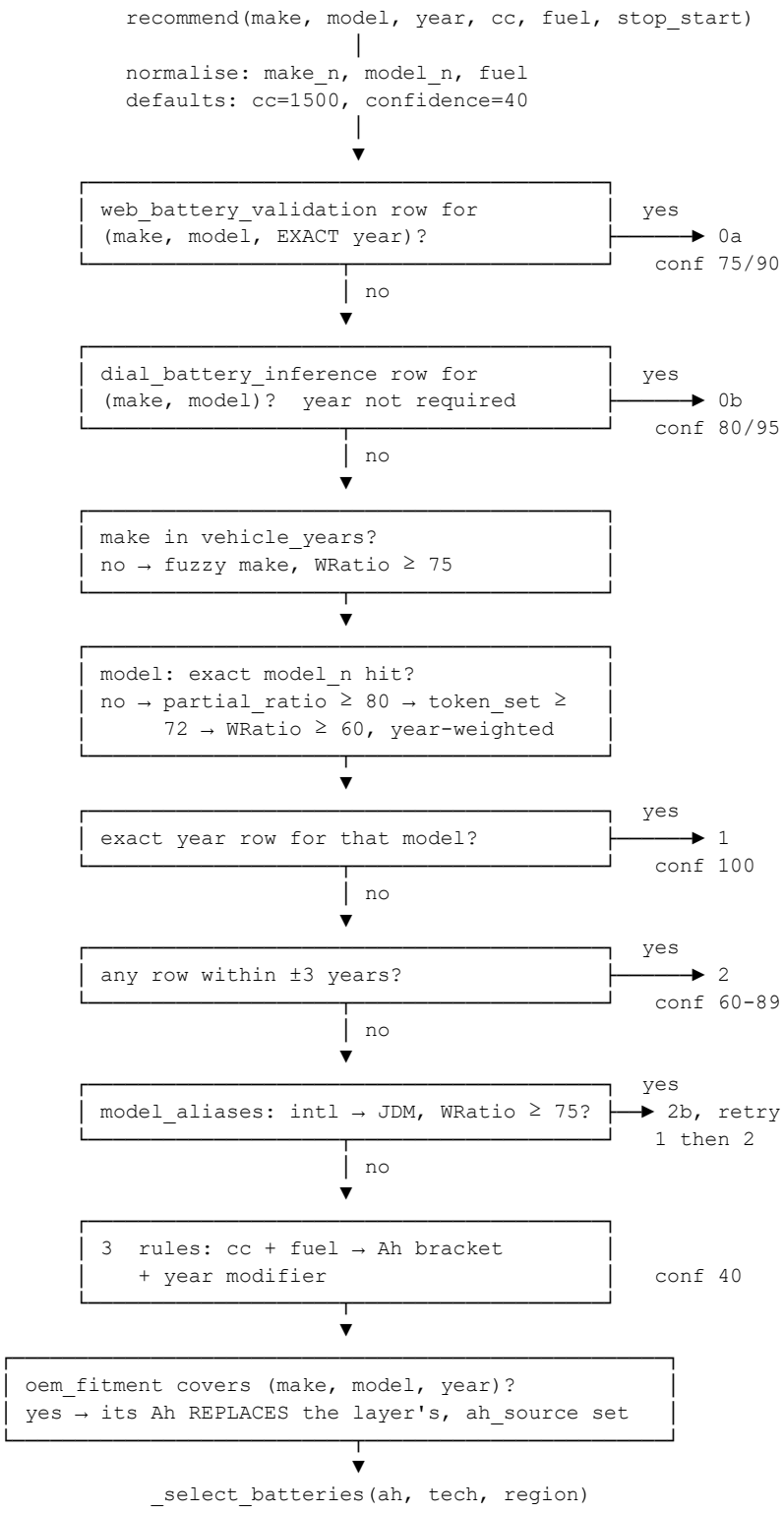
Once `target_ah`, `preferred_tech` and `region` are known:

1. Filter `battery_specs` to the correct region.
2. Filter to rows where `Ah == target_ah`.
3. Sort by technology preference order: `EFB > AGM > MF > SB (Flooded)`.
4. Within the same technology, sort imported before local.
5. If `preferred_tech` is stocked at `target_ah` → that becomes the primary.
6. If not → take the best available technology at the same Ah.

7. If nothing exists at `target_ah` → take the nearest Ah in any technology.
8. **Alternatives:** same Ah, same CCA and same technology as the *actual* primary — not the target — capped at 6, imported first. Using the primary's real Ah matters for step 7, where the primary may have stepped to a different Ah than requested.

Matching Engine — Decision Flow

The layers described above compose into the decision tree below. Read it top to bottom; the first box that returns is the answer.



Note the asymmetry between 0a and 0b: web validation demands an exact year match and gives up otherwise, because its rows are year-specific claims about a particular model year. Inference has no year requirement at all — a call centre's sales record for "Corolla" is evidence about the nameplate, not about one model year — so it consults `vehicle_years` afterwards only to fill in engine specs for the response.

Worked Example 1 — exact match with an OEM override

Request: `TOYOTA / Corolla Axio G / 2015 / 1500cc / Petrol / stop_start=true`.

```
0a  web_battery_validation  → no row for (TOYOTA, COROLLA AXIO G, 2015)
0b  dial_battery_inference  → no row for (TOYOTA, COROLLA AXIO G)
1   vehicle_years           → model_n "COROLLA AXIO G" is an exact key → 100
                              year 2015 present → confidence 100, Exact Match
                              engine_capacity 1500, fuel PETROL taken from row
    _preferred_tech(1500, PETROL, 2015, TOYOTA, stop_start=True)
        not EV · TOYOTA not a luxury make · not hybrid
        stop_start and cc < 2500 and not diesel        → EFB
    _target_ah — not consulted: confidence is not 40, so no rule estimate
    oem_fitment → row covers TOYOTA / COROLLA / 2012-2018, ah 55, EFB
                              → target_ah = 55, ah_source = "oem_fitment"
    _select_batteries(55, EFB, NS)
        NS pool, Ah == 55, technology EFB, imported before local
```

Response: `confidence 100`, `match_type "Exact Match"`, `recommended_ah 55`, `preferred_tech "EFB"`, `ah_source "oem_fitment"`. The AccuracyBar shows Car Found 50/50 and Year 25/25.

Worked Example 2 — falling all the way through to rules

Request: `PEUGEOT / 3008 GT LINE / 2019 / 2000cc / Diesel / stop_start=true`, where the model is not in the dataset.

```
0a / 0b                     → no rows
1   make PEUGEOT present, but no model scores above threshold
2   no candidate has a year within ±3
2b  model_aliases has no PEUGEOT entry for "3008 GT LINE"
3   rule-based:
      _target_ah(2000, DIESEL, 2019)
          bracket max_cc 2000, diesel column          → 65
          _year_ah_modifier(2019) — 2018 or later     → +10
                                                      → 75 Ah
      _preferred_tech(2000, DIESEL, 2019, PEUGEOT, True)
          PEUGEOT is not in _LUXURY_MAKES
          stop_start and fuel == DIESEL               → AGM
      _make_region("PEUGEOT")                         → DIN
    oem_fitment → no row (the model never resolved)   → ah_source stays
                                                        "cc_bracket_estimate"
    _select_batteries(75, AGM, DIN)
        nothing stocked at exactly 75 Ah in DIN/AGM
        → best available technology at 75 Ah, else nearest Ah in any tech
```

Response: `confidence 40`, `match_type "Estimated (Rule-Based)"`, `matched_make null`. The frontend shows the amber fallback banner, and the AccuracyBar's Car Found segment is empty.

Worked Example 3 — why the year gate on luxury AGM matters

Request: `BMW / 320i / 2001 / 2000cc / Petrol / stop_start=false`.

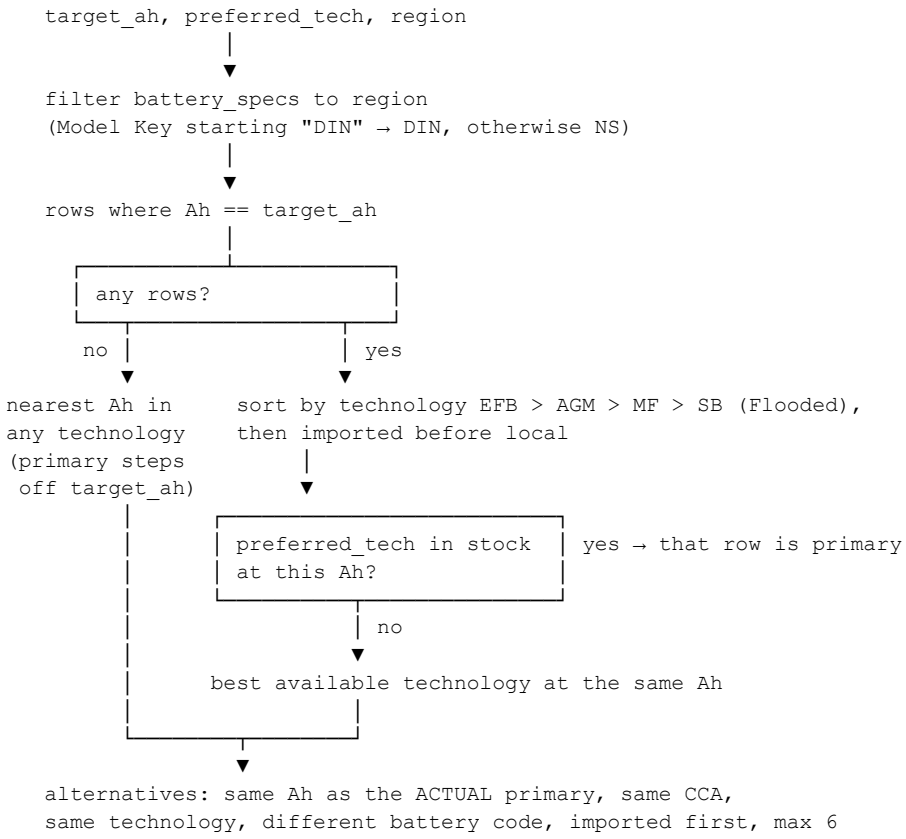
Before the gate existed, `_preferred_tech()` matched "BMW is a luxury make" and returned AGM for every model year. A 2001 320i left the factory on a flooded battery — AGM did not appear on BMWs until brake-energy regeneration arrived around 2007 — so the recommendation was both materially more expensive than the car needs and wrong as a statement of fitment.

```
_luxury_agm("BMW", 2001)
    "BMW" in _LUXURY_MAKES                          → True so far
    _LUXURY_AGM_FROM["BMW"] == 2007;  2001 >= 2007  → False
→ rule does not apply; falls through to the ordinary path
_preferred_tech: not EV, not luxury-gated, not hybrid, stop_start False → MF
```

The same request for a 2015 320i returns AGM, because `2015 >= 2007`.

Selecting the Battery — Decision Tree

`_select_batteries()` turns a target Ah, a preferred technology and a region into one primary battery plus alternatives.



The alternatives filter keys off the primary's real Ah rather than the requested one. When nothing was stocked at the target and the primary stepped to a neighbouring Ah, using `target_ah` here would return an empty list or, worse, a set of alternatives that do not physically match the battery being recommended.

Reading the Code — Key Functions

The normalisation that makes fuzzy matching work at all is small enough to read in full:

```
def _norm_model_key(s: str) -> str:
    """Canonical model name for matching.

    Normalises all common separator/spacing variations so that user inputs
    like "CX5", "CX 5", and "CX-5" resolve to the same key ("CX 5"):
      1. Uppercase + strip
      2. Hyphens → space; collapse repeated spaces
      3. Insert a space at every letter↔digit boundary (CX5 → CX 5)
      4. Final collapse
    """
    s = re.sub(r"[\-]+", " ", s.upper().strip())
    s = re.sub(r"([A-Z])(\d)", r"\1 \2", s)
    s = re.sub(r"(\d)([A-Z])", r"\1 \2", s)
    return re.sub(r"\s+", " ", s).strip()
```

Fuel normalisation is a lookup table rather than logic, and it carries the source data's typos deliberately — the CRSP extract genuinely contains "DEISEL" and "ELECCTRIC":

```
_FUEL_MAP: dict[str, str] = {
    "GASOLINE":        "PETROL",
    "PETROL":          "PETROL",
    "PETROL/ELECTRIC": "PETROL",
    "DIESEL":          "DIESEL",
    "DEISEL":          "DIESEL",          # typo in source data
    "HYBRID":          "HYBRID",
    "PLUG-IN HYBRID":  "HYBRID",
    "EV":              "EV",
    "ELECTRIC(EV)":    "EV",
    "ELECCTRIC":       "EV",              # typo in source data
    "ELECTRIC":        "EV",
}
```

Anything unrecognised becomes `PETROL`, which is the safe default: it produces the smallest Ah of the three main fuel types at any given displacement, so an unknown fuel never inflates the recommendation.

The tie-breaking inside model matching is where most of the accuracy lives. Candidates are not ranked by score alone:

```
def _pick_best(results: list[tuple[str, float, int]]):
    # Prefer semantic prefix matches (candidate starts with user query /
    # first token), then year proximity, then score.
    best_pick = None   # (starts_with, is_exact, -year_delta, score, model_n)
    for cand_model_n, score, _ in results:
        cand_years = _cand_years(cand_model_n)
        if not cand_years:
            continue
        starts_with = 1 if _starts_with_query(cand_model_n) else 0
        if year in cand_years:
            pick = (starts_with, 1, 0, float(score), cand_model_n)
        else:
            nearby_years = [y for y in cand_years if year - 3 <= y <= year + 3]
            if not nearby_years:
                continue
            ...
```

Score is the *fourth* key, not the first. This is what stops a search for a 2011 "FIT" from landing on "FIT SPORT" — several trims tie at score 100 against a short query, and the tuple ordering resolves the tie toward the candidate that actually has rows near the requested year.

The Ah rules are a plain table plus a year modifier, so they can be audited without reading code:

```
_AH_RULES: list[tuple[int, int, int, int]] = [
    # (max_cc_inclusive, petrol_ah, diesel_ah, hybrid_ah)
    (1000,  35,  40,  35),
    (1600,  45,  50,  45),
    (2000,  55,  65,  55),
    (2500,  70,  80,  65),
    (3000,  80,  90,  80),
    (4000,  90, 100,  90),
    (9999, 100, 120, 100),
]

def _year_ah_modifier(year: int) -> int:
    if year >= 2018:
        return 10   # modern electronics era
    if year >= 2012:
        return 5    # early ADAS era
    if year < 2000:
        return -5   # pre-OBD2, minimal load
    return 0
```

The year modifier is applied **only** in rule-based mode. When a real fitment source supplied the Ah, adding a decade-based fudge factor to a known-good figure would corrupt it.

Finally, the per-make cache that keeps all of this fast:

```
@lru_cache(maxsize=128)
def _make_index(make_n: str) -> tuple[pd.DataFrame, dict[str, tuple[int, ...]]]:
    """
    Precompute, once per make, what recommend() and
    _fuzzy_model_score_for_year() otherwise re-derive via a fresh pandas
    scan/filter on every cache-miss call: the make-scoped row slice and a
    model_n -> sorted years sold lookup.
    """
    make_df = _vehicles()[_vehicles()["make_n"] == make_n]
    years_by_model = {
        model_n: tuple(sorted(sub["year"].dropna().unique().astype(int).tolist()))
        for model_n, sub in make_df.groupby("model_n")
    }
    return make_df, years_by_model
```

Before this existed, every candidate a scorer returned — sixty to eighty of them on a common make — triggered its own boolean-mask filter over the full vehicle table just to find out which years that trim was sold in.

6. Matching Mode 1: Select Mode

Select mode is the default user experience. The form uses three cascading dropdowns.

Interaction flow:

```
User selects Make (dropdown)
  → GET /api/makes (loaded on page mount, cached in React state)
  → handleMakeChange() fires GET /api/models/:make
  → models dropdown is populated

User selects Model
  → handleModelChange() fires GET /api/years?make=&model=
  → years dropdown is populated

User selects Year
  → form is ready; user may also choose Fuel Type and Engine CC (optional here)

User clicks "Find Battery"
  → POST /api/recommend with { make, model, year, fuel_type?, engine_cc?,
                               stop_start, input_type: "select" }
```

Why select mode can still use fuzzy matching: the request carries the model name exactly as it appears in the database, since the dropdown was populated from `GET /api/models`. The matcher still normalises it through `_norm_model_key()` and tries an exact match against `model_n` first; when that key is found it bypasses fuzzy matching entirely with score 100. Fuzzy matching only comes into play when the model name in `vehicle_years` differs from the one in a Layer 0 source table.

Confidence in select mode:

- A model chosen from the dropdown matches a `model_n` key exactly → model_score = 100.
- Year present in the database → confidence 100, "Exact Match".
- Year absent but within ±3 → confidence 60–97, "Close Match".
- No year within the window → rule-based fallback, confidence 40.

A Layer 0a or 0b hit can pre-empt all of the above and return 75–95 instead, since those layers are consulted before the vehicle table.

7. Matching Mode 2: Type Mode

Type mode allows free-text entry. This is where the full fuzzy matching pipeline matters.

Interaction flow:

```
User types make, model, year in free-text inputs
User must also provide Fuel Type and Engine CC (required in type mode)

User clicks "Find Battery"
  → POST /api/recommend with all fields, input_type: "type"
```

Estimated confidence indicator (frontend only): Before submitting, the form shows a live estimate to encourage users to fill in every field:

Fields filled	Shown confidence	Label
Make only	40%	"Low — only make entered"
Make + Model	55%	"Fair — add year, fuel type & engine size"
Make + Model + Year	70%	"Good — add fuel type & engine size to improve"
Make + Model + Year + Fuel + Engine CC	85%	"High — all details provided"

This is a UI prompt only — it never reaches the backend, and it disappears on submit, reappearing only when the form is cleared.

Type mode fuzzy matching in the backend:

1. `make_n = make.upper().strip()` — no fuzzy pass on the make initially; if the make yields no rows, a `fuzz.WRatio ≥ 75` make-level fuzzy pass runs.
2. `model_n = _norm_model_key(model)` — normalises separators and inserts letter/digit spaces.
3. `_fuzzy_model_score_for_year()` runs partial_ratio → token_set_ratio → WRatio with year-proximity tie-breaking, as described in Layer 1.
4. If nothing matches, alias resolution (Layer 2b) tries to map the typed name to a JDM equivalent.

Stop-start is an explicit input, not an inference. The form carries its own i-stop selector, defaulting to on, and its value is sent as `stop_start` on every request in both modes. `matcher._infer_stop_start()` — which guessed stop-start from make and year — still exists but is dead code, retained only in case that input is ever made optional again. It is documented here because earlier versions of this document described it as live behaviour; it is not.

8. Authentication & Security

8.1 Admin Authentication (admin_auth.py)

Admin accounts use **bcrypt** (cost 12) for password storage. Sessions are tracked in the `admin_sessions` table.

Login flow:

1. `POST /api/admin/login` with username + password (rate-limited 5/min).
2. If the account is locked, the request is rejected up front with the unlock time.
3. bcrypt comparison runs against a dummy hash even when the user does not exist, so a missing account and a wrong password take the same time.

4. On failure, `failed_login_attempts` increments; at **8 attempts** the account locks for **15 minutes**. A successful login resets both fields.
5. On success: generate a 64-char hex token (`secrets.token_hex(32)`), insert an `AdminSession` row expiring in 8 hours, and set an `HttpOnly; Secure; SameSite=Strict` cookie.

Per-request auth: every admin endpoint depends on `require_admin`, which reads the `admin_session` cookie, looks up the session row, checks expiry, deletes expired sessions as it finds them, and returns the `AdminUser`. All admin routes are covered except `/login` and `/logout`, which must be public.

Cookie security properties:

- `HttpOnly` — JavaScript cannot read the token (XSS mitigation).
- `SameSite=Strict` — blocks CSRF from cross-origin requests. CSRF tokens were explicitly declined on the strength of this.
- `Secure` — HTTPS only in production; disabled for local HTTP dev via `ADMIN_COOKIE_SECURE=false`. The same flag gates the HSTS response header.
- 8-hour TTL, matching the session row.

8.2 Admin Account Lifecycle

There is no CLI script for creating admins; `scripts/create_admin.py` was removed.

First admin (bootstrap). `GET /api/admin/bootstrap/status` and `POST /api/admin/bootstrap` back the public `/admin/setup` page. The endpoint is gated by two conditions: the `admin_users` table must be empty (checked first, so a populated table can never be used as a token-guessing oracle) *and* the request must present the `ADMIN_BOOTSTRAP_TOKEN` shared secret. Once any admin exists the endpoint permanently returns 403 regardless of token.

Bootstrap takes a `pg_advisory_xact_lock` before inserting. "Count the admins, then insert" is not atomic under Postgres's default READ COMMITTED isolation — concurrent transactions can all observe zero before any commits, and distinct usernames mean the unique constraint does not catch it. Eight concurrent requests produced three admins before the lock was added.

Every admin after the first is created from the dashboard via `POST /api/admin/users`, gated by `require_admin` — being logged in is the credential, so no token is involved.

Password reset — two independent mechanisms:

- An admin-generated link (`POST /api/admin/users/{id}/reset-link`): a logged-in admin generates a link for a locked-out colleague and passes it on by hand. Needs no email infrastructure and works today.
- Real email delivery via AWS SES (`email_utils.py`, `SES_FROM_EMAIL` / `SES_REGION`). SES needs domain verification performed in AWS outside this repository; until `SES_FROM_EMAIL` is set, `send_reset_email()` logs a warning and no-ops, so the link mechanism keeps working regardless.

Reset tokens are SHA-256 hashed rather than bcrypt — they are high-entropy CSPRNG values, so bcrypt's deliberate slowness buys nothing. They are single-use, overwritten on reissue, expire after **60 minutes**, and a successful reset invalidates every existing session for that admin.

Admin Users page (`/admin/users`) lists all admins and supports add, delete and reset-link generation. Two rules are enforced server-side: `PATCH /api/admin/users/{id}` returns 403 unless `id` is the caller's own account — letting one admin edit another's email would let them redirect that admin's password-reset destination — and delete blocks both self-deletion and deletion of the last remaining admin.

All of these events are written to `admin_account_audit_log` and surfaced as an Activity feed on the same page.

8.3 Test-User Authentication

Test users register via `POST /api/auth/register` and authenticate via `POST /api/auth/login`. Sessions use Bearer tokens held in client `localStorage` rather than cookies, with a 24-hour TTL. The token is sent as `Authorization: Bearer <token>` on feedback submissions so feedback can be attributed to an account.

8.4 Rate Limiting

All public endpoints are rate-limited via `slowapi`, keyed by client IP:

Endpoint	Limit
`/health`	60/min
`/api/recommend`	10/min
`/api/feedback`	5/min
`/api/makes`, `/api/models/{make}`, `/api/years`, `/api/batteries/search`	20/min
`/api/auth/register`	5/min
`/api/auth/login`	10/min
`/api/admin/login`	5/min

Exceeding a limit returns HTTP 429 with a `retry_after` field. Both `Limiter` instances (one in `app.py`, one in `admin_router.py`) share the single registered `RateLimitExceeded` handler.

Known limitation: `slowapi`'s default storage is in-process, so each application worker keeps its own counters and a per-IP limit is effectively multiplied by the number of workers behind the load balancer. Wiring both limiters to the already-provisioned Redis instance, and adding daily caps on top of the per-minute limits, is a planned change.

8.5 Least-Privilege Public Database Role

Public traffic and admin traffic no longer share a database role. `db.py` exposes two engines:

Engine	Role	Used by
`engine` / `SessionLocal`	`batteryfinder` (full privilege)	`admin_router.py`, `admin_auth.py`, pipelines, scripts
`public_engine` / `PublicSessionLocal`	`batteryfinder_public` (restricted)	`matcher.py`'s loaders, every public route in `app.py`, `app_state.py`

The restricted role is created by migration `20260721_c4d5e6f7a8b9` with exactly the grants it needs: `SELECT` on the matcher's seven read sources plus `app_settings` and `test_users`, and `INSERT` with a narrow `UPDATE` on `search_events`, `user_feedback`, `test_users`, `test_user_sessions` and `admin_stats`. Enforcement is now the database's job rather than a matter of application-code discipline.

Both pools are sized independently via environment variables (section 13.3), because the ceiling that matters is cluster-wide: every worker holds its own pools, so the real connection count is *workers × (DB_POOL_SIZE + DB_MAX_OVERFLOW + PUBLIC_DB_POOL_SIZE + PUBLIC_DB_MAX_OVERFLOW)*, which must stay under Postgres's `max_connections`. With the defaults that is 50 per worker, so a 4-worker deployment can demand 200 connections against a default limit of 100.

8.6 HTTP Security Headers

The `security_headers` middleware sets, on every response:

Header	Value
`X-Content-Type-Options`	`nosniff`
`X-Frame-Options`	`DENY`
`Referrer-Policy`	`strict-origin-when-cross-origin`

Header	Value
`Permissions-Policy`	`geolocation=(), camera=(), microphone=(), payment=(), usb=()`
`Content-Security-Policy`	see below
`Strict-Transport-Security`	`max-age=63072000; includeSubDomains` (only when cookies are in secure mode)

The CSP was verified against the actual built frontend output: `default-src 'self'` with `script-src 'self'`, `object-src 'none'`, `base-uri 'self'`, `form-action 'self'` and `frame-ancestors 'none'`. Two deliberate relaxations exist — `style-src` allows `'unsafe-inline'` because the frontend renders inline `style={{}}` props throughout rather than utility classes, and `img-src` allows `cdn.jsdelivr.net` because the country-flag component fetches flag images from that CDN at runtime.

8.7 Path Handling

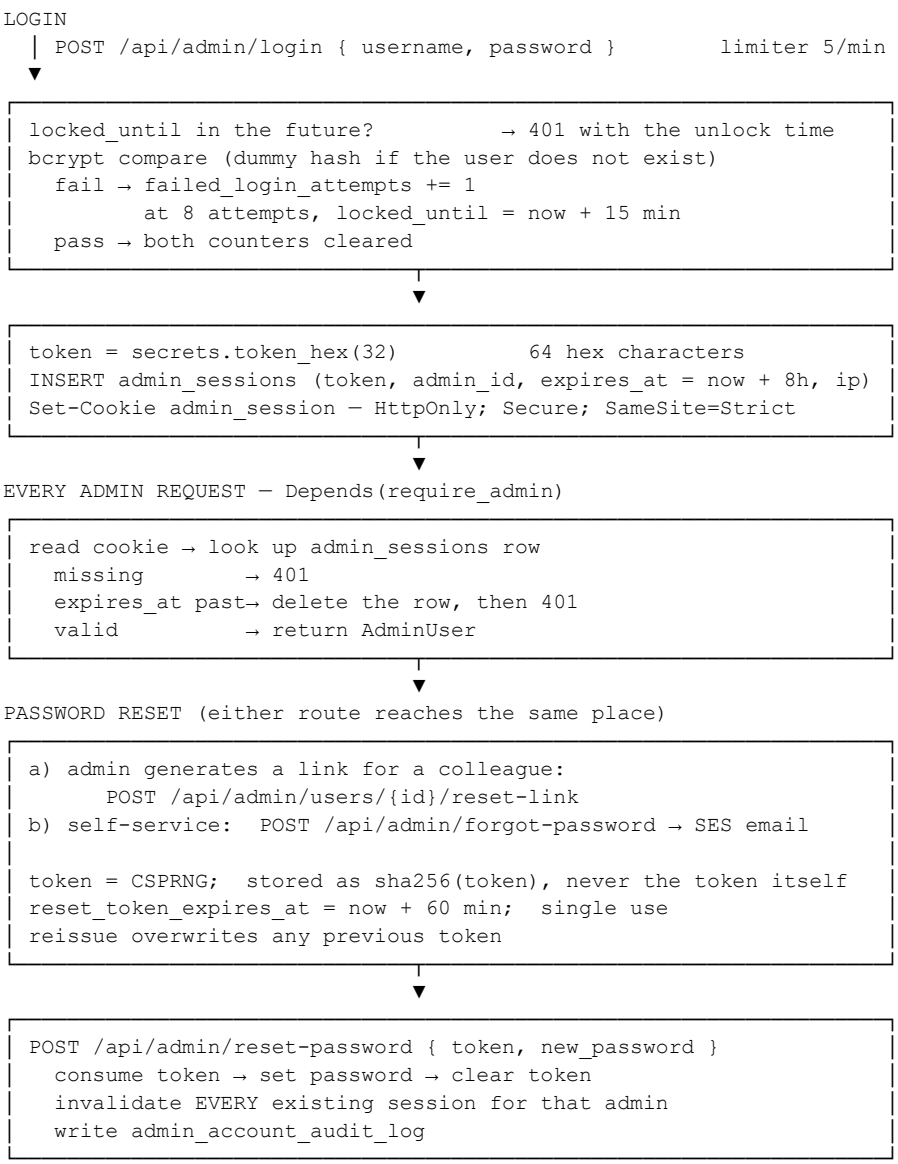
Two endpoints resolve a caller-supplied path, and both normalise and containment-check before trusting it:

- The SPA catch-all in `app.py` (section 3.4).
- `GET /api/admin/backup/{filename}/download`, which uses the same guard to keep downloads inside the backups directory.

One lower-severity instance remains open: `POST /api/admin/pipeline/crsp/validate` and one edit endpoint accept an arbitrary `file_path` in the request body and read it with `pandas`. Both are `require_admin`-gated and constrained to `.xlsx`/`.xls` suffixes, so the caller is already trusted, but they deserve the same normalise-and-contain treatment.

A broader sweep at the same time confirmed: SQL is built with bind parameters throughout (f-strings only splice in hardcoded table and column names); there is no `eval`, `exec`, `subprocess`, `os.system` or `pickle` anywhere in the codebase; all admin routes carry `require_admin` except login and logout; CORS uses an explicit allowlist with no wildcard; and FastAPI is not instantiated with `debug=True`, so unhandled exceptions return a generic 500 rather than a stack trace.

8.8 Admin Session Lifecycle — end to end



Reset tokens are hashed with SHA-256 rather than bcrypt. That is deliberate and is documented inline in `admin_auth.py` so it does not get "corrected" later: bcrypt's value is its slowness against brute-forcing *low-entropy* human passwords. A 32-byte CSPRNG token has no such weakness, and the only thing bcrypt would add is latency on every reset attempt.

8.9 The Bootstrap Race, and the Lock That Fixes It

The first-admin endpoint has to answer "are there no admins yet?" and then create one. Those two steps are not atomic under Postgres's default READ COMMITTED isolation, and because concurrent requests can use different usernames, the unique constraint does not save you either:

```
@router.post("/bootstrap")
@_limiter.limit("3/hour")
def bootstrap(request: Request, body: BootstrapRequest, db: Session = Depends(get_db)):
    # "Check count, then insert" is NOT atomic under Postgres's default
    # READ COMMITTED isolation — two concurrent requests can both see
    # count()==0 before either commits, and since they'd use different
    # usernames the uniqueness constraint doesn't catch it either. This
    # advisory lock serializes all bootstrap attempts against each other
    # (auto-released at transaction end) so only one can ever pass the
    # empty-table check before the row exists.
    db.execute(text("SELECT pg_advisory_xact_lock(:key)"), {"key": _BOOTSTRAP_LOCK_KEY})

    # Check table-emptiness BEFORE the token comparison — a populated
    # table must never be usable as an oracle for guessing the token.
```

The regression test that found this fired eight concurrent bootstrap requests with distinct usernames and got **three** admin accounts. The ordering of the two checks matters independently: emptiness is tested before the token is compared, so an attacker cannot use response timing or status codes against a live system to learn anything about the bootstrap secret.

8.10 What the Restricted Role Can Actually Do

The migration that creates `batteryfinder_public` enumerates its grants explicitly rather than granting on a schema-wide basis, so adding a table does not silently widen public access:

```
_READ_ONLY_TABLES = [
    "vehicle_years", "vehicle_years_exide", "battery_specs", "model_aliases",
    "dial_battery_inference", "web_battery_validation", "oem_fitment",
    "app_settings",
]

# Tables public routes write to. Granted SELECT as well as INSERT/UPDATE —
# not just for reads, but because Postgres also requires SELECT on: (a) any
# column returned by SQLAlchemy's implicit RETURNING after an INSERT, and
# (b) any column referenced in an UPDATE's WHERE clause.
_READ_WRITE_TABLES = [
    "search_events", "user_feedback", "test_users",
    "test_user_sessions", "admin_stats",
]
```

Note what is absent: `admin_users`, `admin_sessions`, every audit log, every staging and versioning table, and `api_usage_quota`. If a vulnerability in a public route were ever exploited to run arbitrary SQL, the connection it runs on cannot read an admin password hash or a session token, and cannot touch the audit trail.

8.11 The Path Traversal Fix, in Full

This is worth reading closely because the same shape recurs anywhere a caller-supplied path is joined to a directory:

```
@app.get("/{full_path:path}", include_in_schema=False)
async def spa_fallback(full_path: str):
    _base = os.path.dirname(__file__)
    # Always serve files from static/ (maintenance assets must load even
    # during maintenance mode)
    if full_path.startswith("static/"):
        candidate = os.path.normpath(os.path.join(_base, full_path))
        static_root = os.path.normpath(os.path.join(_base, "static")) + os.sep
        if candidate.startswith(static_root) and os.path.isfile(candidate):
            return FileResponse(candidate)
    index = os.path.join(_frontend_dir, "index.html")
    file_path = os.path.normpath(os.path.join(_frontend_dir, full_path))
    frontend_root = os.path.normpath(_frontend_dir) + os.sep
    # Serve the actual file if it exists (JS, CSS, assets, etc.) — reject
    # anything that resolves outside frontend_root (path traversal via ../
    # or %2e%2e%2f in full_path)
    if file_path.startswith(frontend_root) and os.path.isfile(file_path):
        return FileResponse(file_path)
    # Otherwise fall back to index.html for client-side routing
    return FileResponse(index)
```

Three details make this correct rather than merely plausible:

- `normpath()` runs **after** the join, not before. Normalising the untrusted segment on its own does not help, because the traversal only resolves once it is attached to the base directory.
- The root is compared with `os.sep` appended. Without it, a sibling directory named `dist-evil` passes a bare `startswith("…/dist")` test.
- A rejected path falls through to `index.html` rather than returning 404, so the endpoint gives no signal about which files exist on disk.

A literal `../` in a URL is collapsed by the browser before the request is sent, which is why this looked safe. URL-encoding the separators as `%2f` survives that, and Starlette does not decode-and-normalise `..` segments before dispatching to the handler. Both `GET /..%2f..%2fbackend%2fapp.py` and `GET /..%2f..%2f.env` returned HTTP 200 with real file contents against a live server before the fix, with no authentication of any kind.

9. Admin Dashboard API

All routes are mounted under `/api/admin/` from `admin_router.py`. Every route requires a valid admin session cookie except `/login` and `/logout`. The surface is roughly 100 routes; they are grouped below.

9.1 Auth & Account Management

Endpoint	Description
`POST /login`, `POST /logout`, `GET /me`	Session lifecycle and current user
`GET /bootstrap/status`, `POST /bootstrap`	First-admin setup (see 8.2)
`POST /forgot-password`, `POST /reset-password`	Self-service reset
`GET /users`, `POST /users`	List and create admins
`PATCH /users/{id}`, `DELETE /users/{id}`	Self-only edit; delete with self/last-admin guards
`POST /users/{id}/reset-link`	Generate a manual reset link for another admin
`GET /users/audit-log`	Account-event history

9.2 Stats & Health

Endpoint	Description

Endpoint	Description
`GET /stats`	Usage counters, per-table row counts (including `oem_fitment` and `vehicle_years_exide`), battery origin/technology breakdown, and today's match-type breakdown
`GET /health`	Connectivity, latency, and connection-pool usage

`GET /health` reports the **cluster-wide** connection count by querying `pg_stat_activity` and `pg_settings` directly, alongside this worker's own in-process pool figure. The per-process number alone was misleading, since each worker only ever knew its own share. Status is `ok`, `degraded` (latency > 500 ms or pool > 85% used), or `down`.

The public, unauthenticated `GET /health` at the application root is a different endpoint: it performs a real `SELECT 1` and returns only `{"status": "ok"}` or a 503, deliberately withholding latency and pool figures from anonymous callers. It is also exempt from the maintenance-mode 503 override so a load balancer can still probe during maintenance.

9.3 Battery CRUD

Endpoint	Description
`GET /batteries`	Paginated list with search and technology filter
`POST /batteries`	Add a battery
`PATCH /batteries/{id}`	Update a battery
`DELETE /batteries/{id}`	Soft-delete a battery
`POST /batteries/upload`	Bulk upsert from Excel (10 MB cap, via `upload_pipeline.py`)
`GET /batteries/export`	Download all active batteries as `.xlsx`

Every mutation writes to `battery_audit_log` and clears and re-warms `matcher._batteries()` immediately, so the next recommendation sees the change.

9.4 Audit, Sessions & Settings

Endpoint	Description
`GET /audit`, `GET /audit/users`	Battery change history, filterable by action, admin, battery code and date range
`GET /sessions`, `DELETE /sessions/{id}`	Admin sessions, with revoke
`GET /test-sessions`, `DELETE /test-sessions/{id}`, `GET /test-users`	Test-user sessions and accounts
`GET /search-events`	Paginated search log
`GET /maintenance`, `POST /maintenance`	Read and toggle maintenance mode (persisted in `app_settings`)
`POST /cache/refresh`	Clear and re-warm every matcher cache, including `_fitment()`

9.5 Feedback Reports

Endpoint	Description
`GET /feedback`	Paginated feedback with accuracy filter
`GET /feedback/summary`	Aggregate statistics
`GET /feedback/export-pdf`	Full report as PDF (ReportLab)
`GET /feedback/export-csv`	Full report as CSV

9.6 Vehicle Data Browsing

Endpoint	Description
`GET /vehicle-data/core`	Paginated, searchable browse of `vehicle_years`
`GET /vehicle-data/oem-fitment`	Paginated, searchable browse of `oem_fitment`
`GET /vehicle-data/oem-fitment/by-make`	Per-make aggregate counts for the brand grid

9.7 CRSP Pipeline (vehicle year enrichment)

Endpoint	Description
`POST /pipeline/crsp/upload`, `POST /pipeline/crsp/validate`	Upload and pre-validate a raw CRSP Excel (10 MB cap)
`POST /pipeline/crsp/dataprep`	Run Stage 1
`POST /pipeline/crsp/run`	Run Stage 2 (year enrichment)
`GET /pipeline/crsp/status`, `POST .../pause`, `.../resume`, `.../cancel`	Long-run control
`GET /pipeline/crsp/staging`, `PATCH /pipeline/crsp/staging/{id}`	Review and edit staged rows
`GET /pipeline/crsp/staging/pre-commit`	Re-run conflict detection against current `vehicle_years`
`POST /pipeline/crsp/staging/commit`, `.../discard`	Commit or discard the run
`GET /pipeline/crsp/versions`, `.../{id}/changelog`, `POST .../{id}/revert`	Version history and rollback
`GET /pipeline/crsp/unmatched`, `POST /pipeline/crsp/rerun-unmatched`	Inspect and retry unresolved models
`GET /pipeline/crsp/provider-health`	Liveness probe across all external enrichment APIs
`POST /pipeline/crsp/fueleconomy/download`, `.../cancel`, `GET .../download-status`	Manage the fueleconomy.gov bulk CSV
`GET /pipeline/crsp/stats`, `.../cache-status`, `POST /pipeline/crsp/cache/refresh`	Dataset counts and cache age

9.8 Web Validation Pipeline

Endpoint	Description
`POST /pipeline/web-validate/run`, `GET .../status`, `POST .../pause`, `.../resume`, `.../cancel`	Run control
`GET /pipeline/web-validate/staging`, `PATCH .../staging/{id}`	Review and edit staged Ah/technology
`GET /pipeline/web-validate/staging/pre-commit`	Re-check conflicts against master
`POST /pipeline/web-validate/staging/commit`, `.../discard`	Commit or discard
`POST /pipeline/web-validate/staging/fix-ah`	Auto-correct suspicious Ah values via a fresh web lookup
`GET /pipeline/web-validate/versions`, `.../{id}/changelog`, `POST .../{id}/revert`	Version history and rollback
`PATCH /pipeline/web-validate/master/{id}`, `DELETE .../master/{id}`	Edit or delete a committed record
`GET /pipeline/web-validate/coverage`, `.../matched`, `.../providers`, `.../staleness`	Coverage reporting and provider status
`POST /pipeline/web-validate/reset-cache`	Clear the lookup cache file and matched rows
`GET /pipeline/quotas`	Per-provider quota usage (rolling monthly, or prepaid balance)

9.9 Coverage Expansion Pipeline

Endpoint	Description
`POST /pipeline/expansion/run`, `GET .../status`, `POST .../pause`, `.../resume`, `.../cancel`	Run control
`GET /pipeline/expansion/makes`, `POST`, `PATCH /{id}`, `DELETE /{id}`	Manage target makes and their per-source slugs

9.10 Backups

Endpoint	Description
`POST /backup`	Trigger an on-demand `pg_dump`
`GET /backup`	List available dumps
`GET /backup/log`	Backup history from `admin_backup_log`
`GET /backup/{filename}/download`	Download a dump (path-traversal guarded)

Backups keep the 10 most recent dumps and prune the rest. See section 16.3 for the two backup modes.

10. Frontend Architecture

10.1 Stack

Concern	Technology
Framework	React 19
Language	TypeScript (strict mode)
Build tool	Vite + Bun
Styling	Tailwind CSS v4 + custom CSS variables
Icons	Lucide React + Heroicons
UI primitives	Radix UI (label, progress, select, switch, tooltip)
HTTP client	Native `fetch` with typed wrappers in `lib/api.ts`
Routing	React Router 7 (SPA, served by the FastAPI catch-all)
Client-side PDF	jsPDF + jspdf-autotable (admin exports)
Testing	Vitest + Testing Library + jsdom

In development, Vite proxies `/api/*` to `localhost:8000`. In production, FastAPI serves the built `frontend/dist/` directory. All admin pages are loaded with `React.lazy()`, so the public bundle never carries dashboard code.

10.2 Key Components

`VehicleFinderForm.tsx` — the main public search form, and the desktop result card. All form state is local React state; there is no external state manager.

- `makes`, `models`, `years` — populated by cascading API calls in Select mode.
- `typeMode` — switches between Select and Type input modes.
- `istop` — i-stop (stop-start) toggle, defaults to `true`, sent as `stop_start` on every request in both modes.
- Estimated confidence bar (Type mode only) — computed from which fields are filled, shown before submission.
- On submit, calls `fetchRecommendation()` and renders the result panel inline.

- The result panel shows the primary battery (Ah, CCA, technology, battery code), the segmented Result Accuracy bar, the same-technology alternatives grid, an amber fallback warning when `matched_make` is null, and the "Rate this result" feedback trigger.

Note for maintainers: this file uses inline `style={{}}` props throughout rather than Tailwind utility classes. Extend it the same way — this is also why the CSP must allow `style-src 'unsafe-inline'`.

`MobileVehicleFinder.tsx` — a separate mobile-optimised finder with its own mode toggle and layout, sharing the same API layer and validation rules (including the 1960–2030 year bounds enforced client-side before submit).

`AccuracyBar.tsx` — four-segment coloured accuracy bar rendered below every recommendation. Each segment's width is proportional to its maximum contribution, and it fills based on match quality computed from `match_type`, `confidence`, `matched_year` and `matched_make`:

Segment	Colour	Max	What it measures
Car Found	Green `#10b981`	50	Whether the vehicle was found in the database (0 on rule-based fallback)
Year	Blue `#3b82f6`	25	Year delta from the matched row (25 exact, 20 delta-1, 13 delta-2, 8 delta-3)
Data Quality	Purple `#8b5cf6`	15	Real-world fitment data (15), structured dataset (12), engine estimate (4)
Engine Info	Amber `#f59e0b`	10	Whether engine details were confirmed from records or inferred

The total (0–100) is shown as a percentage alongside the bar, with a plain-language legend explaining each colour. Like the form, it uses inline styles.

`ConfidenceBar.tsx` — the simpler pre-submission confidence indicator used in Type mode.

`FeedbackModal.tsx` — collects 1–5 star satisfaction, an accuracy rating, which parts were wrong, and free-form comments; submits to `POST /api/feedback`, attaching the Bearer token when a test user is signed in.

Supporting components: `TermsGate` (first-visit terms acceptance), `PrivacyModal`, `CopyrightModal`, `FaqModal`, `HowToUseModal`, `BuildVersionModal`, `Notification`, `PageLoader`, `SkeletonForm`, and a small `ui/` set (`Badge`, `OrbitLoader`, `Skeleton`, `StartStopIcon`).

10.3 Admin Pages (frontend/src/pages/admin/)

Page	Route	Description
`AdminLogin.tsx`	`/admin/login`	Username/password form; sets the session cookie
`AdminSetup.tsx`	`/admin/setup`	First-admin bootstrap (public, token-gated)
`AdminForgotPassword.tsx`	`/admin/forgot-password`	Request a reset email
`AdminResetPassword.tsx`	`/admin/reset-password`	Consume a reset token
`AdminDashboard.tsx`	`/admin/dashboard`	Stats cards and the DB health card
`AdminBatteries.tsx`	`/admin/batteries`	Battery list with search, add, edit, delete, upload, export
`AdminAuditLog.tsx`	`/admin/audit`	Filterable battery audit log
`AdminFeedback.tsx`	`/admin/feedback`	Feedback table, summary stats, PDF/CSV export

Page	Route	Description
AdminSessions.tsx	/admin/sessions	Admin sessions with revoke
AdminTestSessions.tsx	/admin/test-sessions	Test-user sessions and accounts
AdminVehicleData.tsx	/admin/vehicle-data	Browse vehicle_years and oem_fitment
AdminDataPipeline.tsx	/admin/data-pipeline	Run, monitor, review and commit every pipeline
AdminSearchLog.tsx	/admin/search-log	Search-event log
AdminUsers.tsx	/admin/users	Admin accounts and account-activity feed
AdminBackups.tsx	/admin/backups	Trigger, list and download database backups
AdminSettings.tsx	/admin/settings	Maintenance mode and other app settings

Every route above except login, setup, forgot-password and reset-password is wrapped in `ProtectedRoute`, inside the shared `AdminLayout` shell.

10.4 API Layer (lib/api.ts, lib/adminApi.ts, lib/testUserApi.ts)

All HTTP calls go through typed async wrappers. Errors are normalised: a `{ "detail": "..." }` body is re-thrown as an `Error` with that message, so components can catch everything with `err.message`.

```
export async function fetchRecommendation(payload: RecommendRequest):
Promise<RecommendationResult>
// Times out after 8 seconds — covers a cold backend still warming its caches
export async function fetchMakes(): Promise<string[]>
```

Supporting modules: `TestUserContext.tsx` (React context for the test-user session), `maintenance.ts` (detects the 503 maintenance response), `brandBranding.ts` / `makeBranding.ts` (per-brand presentation), and `utils.ts`.

10.5 Two Input Modes — UI Perspective

Select Mode (default):

- Three cascading `<select>` elements (Make → Model → Year).
- Models are disabled until a make is chosen; years until a model is chosen.
- Fuel type and engine CC are optional.
- A hint link — "Don't see your model? Type your query instead" — appears once a make is selected.

Type Mode:

- Three free-text `<input>` elements.
- Fuel type and engine CC are required, since the rule-based fallback needs them.
- The live estimated-confidence bar guides the user toward filling every field.
- The Type/Select toggle switches modes and resets all fields.

11. Data Pipelines

Pipelines live in `backend/pipelines/` and are run either from the admin Data Pipeline page (which spawns a background thread and streams progress) or directly from the CLI with `backend/` as the working directory. Long-running pipelines support pause, resume and cancel from the UI.

The important structural change since version 1.0: **no pipeline writes to a live table directly.** Enrichment output lands in a staging table, an admin reviews conflicts, and only then is it committed — producing a version row and a row-level changelog that makes the commit revertible.

11.1 The CRSP Pipeline (two stages)

```
Stage 1 — pipelines/dataprep.py
  Input:  a CRSP Excel file (uploaded via the admin UI, or a path on disk)
  Output: vehicles_raw table + battery_lookup_dataset.csv / .xlsx
  Does:   parses the raw CRSP dealer dataset, cleans and deduplicates by
          make/model/CC/fuel, and preserves the Model number column
          (the Japanese type-approval / chassis code) for Stage 2.

Stage 2 — pipelines/enrich_years.py
  Input:  battery_lookup_dataset.csv
  Output: vehicle_years_staging  (never vehicle_years directly)
  Does:   for each unique make/model, queries external sources for production
          year ranges, then writes staged rows with per-row validity and
          conflict flags for admin review.
```

Stage 2 source order (first usable answer wins):

#	Source	Notes
1	fueleconomy.gov bulk CSV	US EPA, 1984–present, exact per-year data. Cached in the `fueleconomy_vehicles` table
2	CarAPI	Community year ranges
3	CarQuery	Community year ranges
4	Japanese Wikipedia	Generation-level production data with chassis codes — `pipelines/ja_wikipedia_years.py`
5	English Wikipedia	Article extracts containing year mentions
6	NHTSA VPIC	Fallback model list; confirms a model exists but carries no per-year data

Wikidata was removed as a source. Its `P571` inception date has no lower bound and returns the *nameplate's* founding year rather than any generation's start — this is literally why a Land Cruiser was once stored as starting in 1951. Japanese Wikipedia supersedes it with real generation-level data.

`ja_wikipedia_years.py` is worth describing separately, since it solves a coverage problem no threshold change could. `ja.wikipedia.org` publishes a structured table per *generation* with exact production periods and manufacturer chassis codes, for Japanese and Western makes alike. The module resolves a title (English Wikipedia search → `langlinks` → the Japanese title, with a scored fallback and an honest "unresolved" rather than a guess), then extracts years from two shapes that must both be supported because articles often have one and not the other: section headings such as `40 系（1960 年 – 1984 年）`, and per-generation infobox 販売期間 fields. It parses Japanese date notation, imperial-era calendars, and open-ended ranges, and uses `mwparserfromhell` rather than regular expressions because real infobox values nest templates that a naive pattern silently mis-reads.

Two safety properties matter operationally. Requests are spaced at least 1 second apart, and any non-200 or non-JSON response raises a `ThrottledError` that propagates to every caller — a throttled response is **never** recorded as "no data", which is exactly how bad year data entered the table historically. And where a trim cannot be attributed to a specific generation unambiguously, the module returns no match with the candidates attached rather than guessing.

Chassis codes as matching input. CRSP's `Model number` column holds real Japanese type-approval codes (`3BA-VJA300W-GNUZZ`). `extract_chassis_code()` strips the classification prefix to recover the generation code

(`VJA300W`), which disambiguates which generation a trim belongs to far more reliably than the model text. The code is carried through staging into `vehicle_years.model_number` but is deliberately excluded from conflict detection — it is a matching input, not a spec value worth blocking a review over.

`pipelines/oem_fitment_years.py` is a second, zero-cost year source that reads the `oem_fitment` table instead of any network service. It exists because Japanese Wikipedia documents JDM passenger cars well and commercial vehicles barely at all; for battery fitment specifically, the manufacturer's own guide is arguably the better authority anyway.

11.2 Web Battery Validation (web_battery_validate.py)

Queries external search providers in order — **SearXNG → DuckDuckGo → Brave → Tavily** — for the internet-accepted battery for each `(make, model, year)` not already present in `web_battery_validation`. Results go to `web_battery_staging` for review, then to the master table where `matcher._web_validation()` picks them up as Layer 0a.

Provider use is metered against `api_usage_quota`, with quota reservation done atomically so concurrent workers cannot both consume the last call. Quota bookkeeping is cached in memory and flushed once per run; before that, a single run could cost more than 10,000 database round-trips on quota checks alone. DuckDuckGo is unmetered and carries the bulk of the volume; Brave is a prepaid balance that never auto-resets, so it is queried at nameplate level rather than per variant.

The battery region for a resolved row always comes from the vehicle's own make, never from a "NS"/"DIN" keyword found in the scraped text — trusting the scraped value put DIN-coded batteries on 490 NS-region vehicles before it was fixed.

11.3 Other Pipelines

```
pipelines/exide_fitment_clean.py
  Input:  the Exide global fitment guide Excel
  Output: oem_fitment (full truncate + reload on every run)
  Note:   vehicle_years is never written to; vehicle_years_exide is a view
          over oem_fitment and therefore updates automatically.

pipelines/dial_battery_clean.py
  Input:  data/Dial-A-Battery Data - 2023-2026.xlsx
  Output: dial_battery_inference
  Does:   cleans and normalises call-centre order data, aggregates by
          vehicle type + model + battery code, counts frequency.

pipelines/vehicle_coverage_expansion.py
  Input:  the expansion_makes table (managed from the admin UI)
  Output: vehicle_years_staging (same review-and-commit workflow)
  Does:   expands coverage beyond the CRSP catalogue using NHTSA VPIC,
          CarQuery, cars-data.com and car.info, with a per-make year tier.

pipelines/generate_battery_lists.py   — battery list generation helper
pipelines/model_name_utils.py         — shared make/model cleaning helpers
```

`backend/scripts/` holds roughly fifty standalone remediation and reporting scripts (data fixes, quarantine passes, audits, workbook exports). They are not part of the application runtime. The convention they follow is worth knowing: dry-run by default with an explicit `--execute` flag, a real database backup taken first and logged to `admin_backup_log`, and a `vehicle_years_versions` / `vehicle_years_changelog` entry written so the change can be reverted from the admin UI like any other commit.

11.4 Upload Pipeline (upload_pipeline.py)

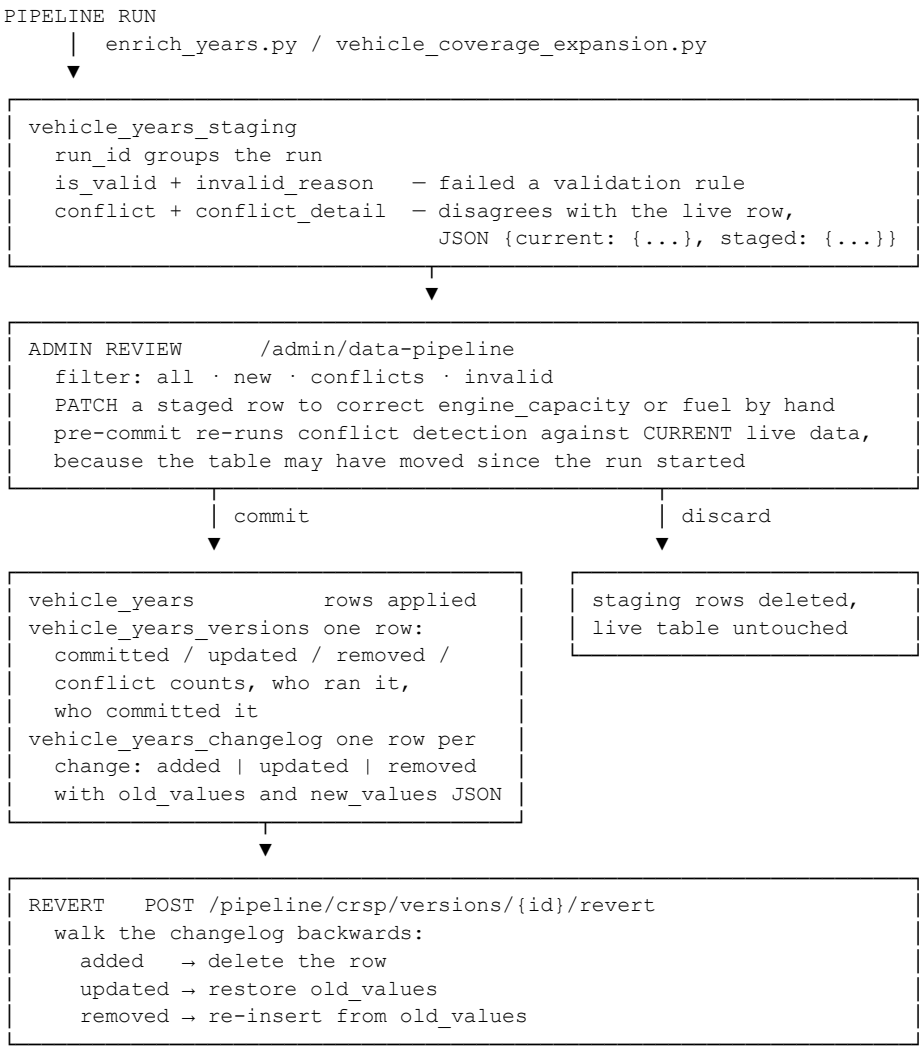
The admin dashboard's battery Upload feature uses this module. It accepts an Excel file up to 10 MB and performs:

- **Column aliasing** — accepts multiple column-name variants (`battery_code` / `code` / `sku`, `model_key` / `model`, `ah` / `capacity_ah`, …).
- **Row validation** — `battery_code`, `model_key`, `ah` (numeric, > 0) and `technology` are required; `cca_en` is optional. Any row missing a required field or failing a type check is rejected, and valid rows still commit.
- **Merge rules** — INSERT if new, UPDATE if changed, SKIP if identical.
- **Audit logging** — every INSERT and UPDATE writes to `battery_audit_log`.
- **Last-write-wins** — duplicate battery codes within one file take the last occurrence, with a warning.

Returns `{ inserted, updated, skipped_unchanged, rejected, errors }`.

11.5 Staging, Commit and Revert — the safety net

No pipeline writes to a live table. Everything lands in staging, is reviewed, and only then is committed — and every commit can be undone.



The changelog is what makes the revert possible: storing only "version 4 changed 7,185 rows" would let you see the damage without undoing it. Storing `old_values` per row means the previous state is recoverable field by field.

Conflict detection is deliberately narrow about which columns count:

```
# same key, different engine_cc or fuel → conflict=1, conflict_detail=JSON
```

`model_number` is carried through staging but is excluded from this comparison. It is a matching *input* — the chassis code used to pick the right generation — not a spec value a reviewer needs to adjudicate. Including it would have marked every already-correct row as conflicting the moment the column started being populated, burying the real conflicts in noise.

11.6 Rate Limiting an External Source Safely

The Japanese Wikipedia parser illustrates a failure mode worth generalising. A throttled MediaWiki response is an HTTP error page, not JSON. Parsed by a lenient `except`, it looks exactly like "this vehicle has no data" — and gets recorded as such:

```
class ThrottledError(RuntimeError):
    """Raised when the API returns something other than a normal JSON body.

    Never caught and treated as "no data" — that is precisely how bad year
    data entered this table in the first place.
    """
```

The contract is that `ThrottledError` propagates to every caller and aborts the run. A run that stops halfway with a clear error is recoverable; a run that completes having silently written thousands of "no data" verdicts is not — and you find out months later, from a customer.

The same principle governs the trim-to-generation matcher: where a trim cannot be attributed to exactly one generation, it returns no match with the candidate list attached, rather than guessing. Unresolved nameplates are logged as residue and left for a human. Across the full cleanup pass this "decline rather than guess" behaviour fired correctly seven times on genuinely ambiguous nameplate groups — including one where a single confident-looking match would have deleted real Land Cruiser Prado year rows, because `extract_base_model()` collapses "LAND CRUISER ZX" and "LAND CRUISER PRADO TX" into the same nameplate group.

12. Rate Limiting & Observability

12.1 Rate Limiting

Implemented with `slowapi`, keyed by client IP; per-route limits are listed in section 8.4. On `RateLimitExceeded` the API returns:

```
{
  "detail": "Rate limit exceeded. Please try again later.",
  "retry_after": "10 second"
}
```

Registering that handler was itself a fix — the function existed but was never wired up, so exceeding a limit previously produced an unhandled 500 instead of a clean 429.

12.2 Read Counter

The admin dashboard's "reads today" figure counts `POST /api/recommend` calls:

1. `count_reads_middleware` increments an in-memory counter on each recommendation request.
2. `_flush_read_counter()` fires every 60 seconds and writes the accumulated delta to `admin_stats` (`stat_key = "db_reads"`) in one write.
3. `_reset_daily_reads()` fires at local midnight, zeroing both the stored value and any pending in-memory delta.

12.3 Search Events

Every recommendation also writes a `search_events` row from a background thread: what was asked for, what was returned, the match type and confidence, whether anything matched, a truncated client IP, and whether the

request came from Select or Type mode. This is the data behind the admin Search Log and the dashboard's match-type breakdown, and it is the primary signal for deciding which vehicles deserve manual data attention.

The write is one INSERT per request on the public role's connection. At current volumes that is fine; it is the first thing to batch if traffic grows substantially, and `search_events` retention is the main driver of long-term database size.

12.4 Health Endpoints

`GET /api/admin/health` (admin-only) returns full diagnostics:

```
{
  "status":              "ok",
  "connected":           true,
  "latency_ms":          3.2,
  "cluster_connections": 14,
  "max_connections":     100,
  "pool_size":           10,
  "pool_checked_out":    1,
  "pool_usage_pct":      9.1
}
```

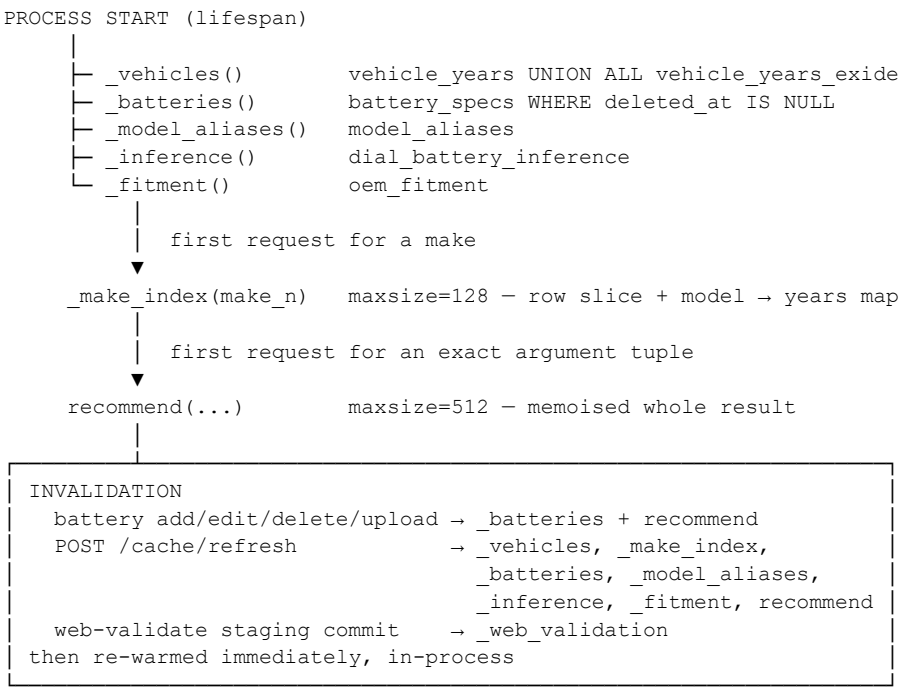
`cluster_connections` comes from `pg_stat_activity` and `pg_settings` — ground truth from Postgres itself, independent of which worker answers the request. The per-worker pool figures are reported alongside it as a secondary "this instance" reading. Status degrades to `degraded` above 500 ms latency or 85% pool usage, and `down` when the database is unreachable.

`GET /health` (public, unauthenticated, 60/min) performs a real `SELECT 1` and returns only `{"status": "ok"}` or a 503 — intended for the load balancer's target-group health check, and deliberately exempt from the maintenance-mode override so probes still succeed during maintenance.

13. Performance & Caching Strategy

13.1 Why the Matcher Holds Everything in Memory

The recommendation path does no database work. Every source table is read once into a pandas DataFrame and kept in an LRU cache for the life of the process. This is affordable because the working set is small — tens of thousands of vehicle rows and a few thousand battery SKUs — and it removes both database latency and connection-pool pressure from the hot path entirely.



`recommend()` itself is memoised at `maxsize=512`. Real traffic is heavily skewed toward a small set of popular vehicles, so this absorbs most repeat lookups without recomputing any fuzzy matching at all. It is cleared alongside the data caches — a memoised result computed from stale battery data would otherwise outlive the data it came from.

13.2 Cost of Each Layer

Layer	Work done	Relative cost
`recommend()` cache hit	Dictionary lookup	Negligible
0a / 0b	Two DataFrame filters plus at most one `extractOne` over the models for one make	Low
1 / 2	Up to three `rapidfuzz` scorer passes over one make's model list, then the tie-break sort	Moderate — the dominant cost
2b	Alias lookup plus a second fuzzy pass per resolved JDM candidate	Highest, but only reached when everything else failed
3	Table lookup and arithmetic	Negligible

The expensive case is therefore a *miss* — a vehicle that reaches alias resolution and still fails. That is also the case where the answer is least useful, which is a reasonable trade: the system spends its time on the searches that are hardest to satisfy.

13.3 Connection Pools

Two engines, each with its own pool, and the ceiling that matters is cluster-wide rather than per process:

```
total connections = workers x ( DB_POOL_SIZE + DB_MAX_OVERFLOW
                              + PUBLIC_DB_POOL_SIZE + PUBLIC_DB_MAX_OVERFLOW )
```

With the defaults (10 + 15 for each of the two pools) that is 50 per worker, so four workers can demand 200 connections against Postgres's default `max_connections` of 100. The application will exhaust connections long before it exhausts CPU or memory, and the failure presents as timeouts rather than as anything obviously

connection-related. Self-hosted deployments should lower the pool variables, raise `max_connections`, or put pgbouncer in front.

The malformed-value behaviour is deliberate:

```
def _int_env(name: str, default: int, minimum: int = 0) -> int:
    """Read a non-negative integer from the environment, falling back to
    `default`.

    Raises rather than silently falling back on a malformed value — a typo in
    a pool-size variable would otherwise be invisible until the app ran out of
    connections under load.
    """
    raw = os.environ.get(name)
    if raw is None or not raw.strip():
        return default
    try:
        value = int(raw.strip())
    except ValueError:
        raise RuntimeError(f"{name} must be an integer, got {raw!r}.") from None
    if value < minimum:
        raise RuntimeError(f"{name} must be >= {minimum}, got {value}.")
    return value
```

A typo fails the process at startup, where it is obvious, instead of silently reverting to a default and failing under load a week later.

13.4 Other Performance Work

- **Per-make index.** `_make_index()` removed a full-table pandas scan per candidate during fuzzy matching. On a make with many trims that was sixty to eighty scans for one request.
- **N+1 elimination in the pipelines.** Quota accounting in `web_battery_validate.py` was one database round-trip per check — more than ten thousand per run. It now uses an in-memory cache flushed once at the end. The staging endpoints (`_populate_staging`, `staging_pre_commit`, `commit_staging`) bulk-load existing keys instead of querying per row, changelog inserts are batched, and `revert_crsp_version()` uses a single `tuple_()`-keyed `IN` query rather than one `SELECT` per changelog row.
- **Response compression.** GZip above 500 bytes.
- **Immutable asset caching.** Vite emits content-hashed filenames, so `/assets/*` is served with a one-year `max-age` and `immutable`.
- **Lazy admin bundle.** Every admin page is behind `React.lazy()`, so a member of the public never downloads dashboard code.

14. Error Handling & Failure Modes

16.1 How Errors Reach the Client

Condition	Status	Body
Request fails schema validation	422	Every field error flattened into one readable `detail` string
Rate limit exceeded	429	`detail` plus `retry_after`
No models or years for the requested vehicle	404	`detail` naming the make/model
Spec search with neither `ah` nor `cca`	422	`detail` listing the accepted parameters
Admin route without a valid session	401	`detail`

Condition	Status	Body
Admin editing another admin's email	403	`detail`
Unhandled exception	500	Generic message — FastAPI is not in debug mode, so no traceback is returned
Maintenance mode	503	The static maintenance page
Database unreachable at `/health`	503	`{"status": "down"}`

16.2 Failures That Are Deliberately Swallowed

Three paths log and continue rather than failing the request, because the user's answer does not depend on them:

- **Search-event logging.** Runs on a daemon thread; a failure is logged at debug level. A telemetry outage must never cost a customer their recommendation.
- **Read-counter flush.** A failed flush logs a warning and the timer reschedules. The counter is a dashboard statistic, not an accounting record.
- **Maintenance-mode refresh.** If the settings lookup fails, `app_state` keeps its previous cached value rather than raising on every request. The consequence is that a maintenance toggle may not propagate during a database outage — acceptable, since a database outage is already visible through `/health`.

Everything else propagates.

16.3 Degradation Behaviour

What breaks	What happens
`oem_fitment` empty or missing	`_fitment()` returns an empty DataFrame; the override never fires; recommendations fall back to their layer's own Ah
`web_battery_validation` empty	Layer 0a never fires; Layer 0b onward is unaffected
`dial_battery_inference` empty	Layer 0b never fires
`model_aliases` empty	Alias resolution is skipped; international model names simply fail to match
Database down at startup	Startup fails fast in `lifespan` — deliberate; a worker that cannot load its caches must not accept traffic
Database down while running	Recommendations keep working from cache; writes to `search_events` and `admin_stats` fail silently; `/health` reports 503

The last row is worth underlining: because the matcher is fully in-memory, the public battery finder keeps answering correctly through a database outage. Only telemetry and the admin dashboard degrade.

16.4 Known Issues

Stale Layer 0a data after editing a committed web-validation record. `matcher._web_validation()` is invalidated in exactly one place — the staging commit in `admin_router.py`. It is *not* cleared by `POST /api/admin/cache/refresh`, nor by `PATCH`/`DELETE` on a master record, nor by a version revert, nor by `reset-cache`. Editing, deleting or reverting committed web-validation data therefore leaves the matcher serving the previous values until the process restarts, and the general cache-refresh button does not fix it. This is the same class of bug the commit path already fixed once, and the same fix applies: add `matcher._web_validation.cache_clear()` to `refresh_cache()` and to the four master-mutation routes.

Per-IP rate limits are multiplied by the worker count. `slowapi`'s default storage is in-process. Each worker keeps its own counters, so the effective limit is the configured limit times the number of workers, and every deploy resets them. Redis is provisioned and unused; pointing both `Limiter` instances at it with `storage_uri` is the intended fix.

Two admin endpoints trust a caller-supplied file path. `POST /pipeline/crsp/validate` and one edit endpoint accept an arbitrary `file_path` in the request body and open it with pandas, without confirming it resolves inside the uploads directory. Both require an admin session and only accept `.xlsx`/`.xls`, so the exposure is limited to an already-trusted caller, but they should get the same normalise-and-contain treatment as the SPA fallback.

Long-running pipelines are tied to one worker. Pipeline state lives in process memory, so the pause, resume, cancel and status endpoints only work against the worker that started the run. Behind a load balancer with multiple workers, a control request can land on a worker that knows nothing about the run.

15. Automated Test Suite

15.1 Backend (backend/tests/, pytest)

`conftest.py` wires a minimal FastAPI app around `admin_router`'s routes against a real local Postgres, and wraps each test in a transaction that is rolled back afterwards, so database writes never persist. A separate `public_db_session` fixture keeps tests that exercise public-route writes inside that same transaction rather than leaking rows through the restricted role's own connection.

One caveat worth knowing: rollback covers database state only, **not filesystem side effects**. A route that deletes a cache file on disk needs that call mocked directly.

File	Covers
`test_matcher.py`	Normalisation, Ah brackets, technology rules, each matching layer
`test_admin_battery_crud.py`	Battery CRUD edge cases, including soft-deleted code reuse
`test_admin_crsp_pipeline.py`	CRSP staging commit / discard / revert lifecycle
`test_admin_web_validate_pipeline.py`	Web-validation staging and versioning
`test_web_validate_staging_and_quota.py`	Staging lifecycle and the quota race condition
`test_web_validate_region_resolution.py`	DIN/NS region resolution, both directions
`test_admin_account_management.py`	Bootstrap, reset, user management, bootstrap concurrency
`test_admin_backup.py`	Backup success/failure logging, listing, traversal rejection
`test_admin_vehicle_data.py`	Vehicle-data browse endpoints
`test_admin_health.py`, `test_health_endpoint.py`	Both health endpoints
`test_enrich_years_matching.py`	Fuzzy-match case handling, trim stripping, span capping, chassis-code parsing
`test_ja_wikipedia_parser.py`	Heading and infobox extraction, trim-to-generation matching

Several of these tests were written because a bug was suspected, and found real ones: a 500 on reusing a soft-deleted battery code, a model/schema type mismatch that made two staging filters fail in production, and the bootstrap race described in 8.2.

```
cd backend
pytest                              # run everything
pytest --junitxml=test-results.xml  # what CI runs
```

15.2 Frontend (frontend/, Vitest)

Component and module tests live beside their subjects as `*.test.tsx` / `*.test.ts`, covering `VehicleFinderForm`, `AccuracyBar`, `ConfidenceBar`, the admin pages, `ProtectedRoute`, `AdminLayout`, and the API and utility modules.

```
cd frontend
bun run test        # watch-free run
bun run test:ci     # JUnit report for Jenkins
```

16. Deployment & Environment

16.1 Environment Variables

`.env` lives at the repository root and is loaded by `python-dotenv` in `db.py`, which walks up from wherever the process started. It is loaded with `override=False`, so real environment variables — the ones ECS injects from SSM Parameter Store and Secrets Manager in production — always win over anything in the file. A stray `.env` baked into a production image therefore cannot clobber a real secret.

Variable	Required	Purpose
`DATABASE_URL`	Yes	Connection string for the full-privilege `batteryfinder` role
`PUBLIC_DATABASE_URL`	Yes	Connection string for the restricted `batteryfinder_public` role. Same host and database, different user
`PUBLIC_DB_PASSWORD`	Migration only	Password used when migration `20260721_c4d5e6f7a8b9` creates the restricted role. Not read by the running app
`ADMIN_COOKIE_SECURE`	No	`false` for local HTTP dev (default `true`); also gates the HSTS header
`ADMIN_BOOTSTRAP_TOKEN`	Before first setup	Shared secret required by `/admin/setup`. Irrelevant once any admin exists
`ALLOWED_ORIGINS`	No	Comma-separated CORS allowlist. Empty by default — the SPA and API are same-origin
`DB_POOL_SIZE` / `DB_MAX_OVERFLOW`	No	Admin pool sizing (defaults 10 / 15)
`PUBLIC_DB_POOL_SIZE` / `PUBLIC_DB_MAX_OVERFLOW`	No	Public pool sizing; each falls back to the corresponding admin value
`DB_BACKUP_MODE`	No	`docker` (default) or `direct` — see 16.3
`DB_BACKUP_CONTAINER` / `DB_BACKUP_USER` / `DB_BACKUP_NAME`	No	Backup target overrides
`SES_FROM_EMAIL` / `SES_REGION`	No	Verified SES sender for reset emails; the feature no-ops with a warning if unset
`SEARXNG_URL`	No	SearXNG base URL for web validation; skipped if unset

Variable	Required	Purpose
`BRAVE_SEARCH_API_KEY` / `BRAVE_MONTHLY_QUOTA`	No	Brave provider and its quota override (default 2000)
`TAVILY_API_KEY` / `TAVILY_MONTHLY_QUOTA`	No	Tavily provider and its quota override (default 1000)

Pool-size variables are parsed by a helper that **raises on a malformed or negative value rather than falling back silently** — a typo in a pool-size variable would otherwise stay invisible until the application ran out of connections under load. Maintenance mode is not an environment variable; see section 3.4.

16.2 Dependency Sets

`requirements.txt` is split three ways, each including the previous:

File	Contents
`requirements.txt`	Runtime only — everything needed to serve the app. This is all a production web host needs
`requirements-pipeline.txt`	Adds pipeline dependencies (BeautifulSoup, lxml, `mwparserfromhell`, DuckDuckGo and Tavily clients)
`requirements-dev.txt`	Adds pytest, httpx, type stubs and the notebook tooling. This is what CI installs

Two allocations are easy to get wrong and are worth stating explicitly: `xlrd` is **runtime**, not pipeline, because the admin upload endpoints accept `.xls` and pandas needs it; and `lxml` is pipeline-only despite never being imported by name, because it is passed as a string to BeautifulSoup.

On Windows with recent Python versions, `mwparserfromhell` has no prebuilt wheel and would need MSVC build tools. Install it with `WITH_EXTENSION=0` to use its documented pure-Python tokenizer instead — same library, same behaviour, no compiler.

16.3 Database Backups

`db_backup.py` supports two modes, chosen with `DB_BACKUP_MODE`:

- **`docker`** (default) — runs `pg_dump` inside the local Postgres container via `docker exec`, matching what `db-backup-script/backup-db.ps1` does.
- **`direct`** — runs a local `pg_dump` over TCP, with host, port, user, database and password all derived from `DATABASE_URL` itself, so a backup can never target a different database than the one being served. This is the mode that works against RDS and against a native Postgres install on a self-hosted box. The password is passed through `PGPASSWORD` in the child environment, never in the argument list, because the process table is world-readable.

Backups are written to `backups/`, the ten most recent are kept, and every attempt — success or failure — is recorded in `admin_backup_log`. A failed direct dump removes its own zero-byte output file, which `pg_dump` creates before it has even connected and which would otherwise be listed as a real backup.

16.4 Starting the Server

Development:

```
docker compose up -d              # local Postgres 15 on host port 5434
cd backend
pip install -r requirements-dev.txt
alembic upgrade head
uvicorn app:app --reload          # http://localhost:8000

cd frontend && bun install && bun run dev    # http://localhost:5173
```

Production (behind a load balancer):

```
cd frontend && bun run build      # outputs to frontend/dist/
uvicorn app:app --host 0.0.0.0 --port 8000 \
        --proxy-headers --forwarded-allow-ips="*"
```

FastAPI detects `frontend/dist/` at startup and serves it; all non-API paths fall through to `index.html`.

`--forwarded-allow-ips="*"` is safe only when the application is unreachable except through the load balancer, as on Fargate. On a self-hosted single VM where nginx proxies to uvicorn on the same host, uvicorn is directly reachable, so `"*"` lets any caller that reaches it spoof `X-Forwarded-For` and defeat *every* per-IP rate limit. Use `--forwarded-allow-ips="127.0.0.1"` and bind to `127.0.0.1` instead of `0.0.0.0` there.

Note that the local Postgres container publishes on host port **5434**, not 5432. A native Postgres install commonly already owns 5432, and on Windows Docker Desktop would bind the container's side on IPv6 rather than erroring — silently splitting `localhost:5432` across two different databases.

16.5 CI/CD (Jenkinsfile)

#	Stage	What it does
1	Checkout	Pull source
2	Set up Python	`pip install -r backend/requirements-dev.txt`
3	Set up Node.js & Bun	Install Bun, then `bun install`
4	Lint Frontend	`bun run lint`
5	Build Frontend	`bun run build`
6	Test Frontend	`bun run test:ci` (Vitest, JUnit output)
7	Start test database	`docker compose up -d` then `alembic upgrade head`
8	Test Python	`pytest --junitxml=test-results.xml`
9	Archive Artifacts	Store `frontend/dist/**`

The post block always publishes JUnit results and tears the database container down. The Python test stage genuinely fails the build — an earlier version swallowed pytest failures silently.

16.6 First-Time Setup

```
# 1. Environment
#    Create .env at the repo root with DATABASE_URL and PUBLIC_DATABASE_URL
#    (see 16.1, and README.md's Environment Variables section)

# 2. Database
docker compose up -d
cd backend
alembic upgrade head          # also creates the batteryfinder_public role
                              # when PUBLIC_DB_PASSWORD is set

# 3. First admin account
#    Set ADMIN_BOOTSTRAP_TOKEN in .env, start the app, then visit /admin/setup.
#    There is no CLI script — see section 8.2.

# 4. Seed vehicle and battery data
python pipelines/dataprep.py
python pipelines/enrich_years.py        # → staging; review and commit in the UI
python pipelines/dial_battery_clean.py
python pipelines/exide_fitment_clean.py
#    Seed battery_specs separately via the admin Batteries upload.

# 5. Start the server
uvicorn app:app --reload
```

17. Operations Runbook

Common tasks, in the order an operator is likely to need them.

17.1 Refreshing the Matcher After a Data Change

Any change made outside the admin UI — a script run against the database, a pipeline executed from the CLI — is invisible to running workers until their caches are cleared.

```
Admin dashboard → any page → Refresh Cache
   or
POST /api/admin/cache/refresh      (admin session cookie required)
```

This clears and re-warms `_vehicles`, `_make_index`, `_batteries`, `_model_aliases`, `_inference`, `_fitment` and the memoised `recommend()`. It does **not** clear `_web_validation` (see 14.4); after editing committed web-validation data, restart the workers.

With more than one worker, this only affects the worker that answers the request. Restart the service when you need certainty.

17.2 Running the CRSP Pipeline End to End

```
1. /admin/data-pipeline → CRSP tab → Upload the new CRSP Excel
2. Validate            — checks the sheet before anything is written
3. Stage 1: Dataprep   — populates vehicles_raw + battery_lookup_dataset.csv
4. Stage 2: Enrichment — writes vehicle_years_staging; watch the log stream
5. Review staging      — filter to Conflicts first, then Invalid, then New
6. Pre-commit          — re-checks conflicts against current live data
7. Commit              — writes vehicle_years, creates a version + changelog
8. Refresh cache       (17.1)
```

Stop at step 5 if the conflict count is unexpectedly high; that usually means the source file's shape changed rather than that the data is wrong.

To undo: `/admin/data-pipeline` → Versions → the version → Revert. This walks the changelog backwards and restores prior values row by row.

17.3 Taking and Restoring a Backup

```
Admin dashboard → Backups → Take Backup
   or
POST /api/admin/backup
```

The ten most recent dumps are kept; older ones are pruned automatically. Every attempt, successful or not, is recorded in `admin_backup_log` with the triggering admin's username.

Set `DB_BACKUP_MODE=direct` on any deployment that is not the local Docker container — RDS, or a native Postgres install. In `direct` mode the connection details are derived from `DATABASE_URL` itself, so a backup cannot target a different database than the one being served.

Restoring is deliberately not exposed through the UI. Use `db-backup-script/restore-db.ps1`, or `pg_restore` directly, with the application stopped.

17.4 Putting the Site into Maintenance Mode

```
Admin dashboard → Settings → Maintenance Mode
```

The flag is stored in `app_settings` and cached per worker for five seconds, so every worker and every instance picks it up within five seconds without a restart. Admin routes, `/admin/*`, `/static/*`, `/assets/*` and `/health` continue to serve; everything else returns the maintenance page with HTTP 503. The load-balancer health check is unaffected by design.

17.5 Creating and Recovering Admin Accounts

Situation	Action
Brand-new deployment, no admins yet	Set `ADMIN_BOOTSTRAP_TOKEN`, visit `/admin/setup`
Adding a colleague	Admin Users → Add. No token involved
Colleague locked out, email not configured	Admin Users → their row → Generate reset link, send it to them by hand
Colleague locked out, SES configured	They use `/admin/forgot-password`
Account locked by failed logins	Wait 15 minutes, or reset the password, which clears the lock
Someone left the company	Admin Users → Delete. This also invalidates their sessions

An admin cannot change another admin's email address; the endpoint returns 403. Redirecting someone else's password-reset destination would otherwise be a privilege-escalation path.

17.6 Checking Health

```
GET /health              public, no auth — {"status": "ok"} or 503
GET /api/admin/health    admin — latency, cluster connections, pool usage
```

`degraded` means latency above 500 ms or pool usage above 85%. The cluster connection count comes from `pg_stat_activity` and is the number to watch: if it approaches `max_connections`, reduce the pool variables or add pgbouncer (13.3).

17.7 Provider Quotas and Web Validation

```
/admin/data-pipeline → Web Validation → Quotas
```

DuckDuckGo is unmetered and carries most of the volume. Brave is a prepaid balance that never auto-resets — once spent, it stays spent until topped up. Tavily and Brave both accept a monthly override through their `*_MONTHLY_QUOTA` variables. If SearXNG is configured it is tried first, and it costs nothing.

18. Data Quality — History and Current State

This section exists because the dataset's accuracy problems were not obvious from the code, and the reasoning behind the fixes is worth preserving.

18.1 The Year-Data Problem

A client review flagged implausible year ranges — a Land Cruiser 200-series listed as available from 1951. Investigation found that roughly a third of model variants started implausibly early, producing about 22% phantom rows in `vehicle_years`, and that 98% of rows carried no `source` value at all, so no bad value could be attributed to the source that produced it.

Five distinct defects were responsible:

#	Defect	Effect
1	Fuzzy matching ran case-sensitively against mixed-case external data	"LAND CRUISER" scored 32 against an unrelated "RAV4 EV" instead of 100 against the real entry
2	The match threshold was 45, lowered to compensate for defect 1	"LUTECIA GT" matched EPA's unrelated "GTA" at 46.15 and returned 1987
3	Model names were truncated to two tokens	"LAND CRUISER 250 VX" became "LAND CRUISER", losing the generation marker
4	Wikidata's `P571` inception date had no lower bound	Returned the nameplate's founding year — the literal source of the 1951 Land Cruiser
5	Open-ended year ranges defaulted to the current year	243 variants ran to 2026, including discontinued models

Defect 1 was foundational: the permissive threshold existed to compensate for scores that were being corrupted by case sensitivity. Fixing the case handling first made it possible to raise the threshold to 60 without losing genuine matches — real matches score 85-100 and the false positives top out at 53, so the new threshold sits in a real gap rather than at an arbitrary point.

18.2 What Was Done

- Case-insensitive processing added to every `rapidfuzz` call site.
- Threshold raised 45 → 60, calibrated against both directions.
- `extract_base_model()` now keeps a third token when it is purely numeric, so "LAND CRUISER 250" survives while "320D" style trim codes still do not.
- Wikidata removed entirely as a source.
- Open-ended spans capped at `year_from + 20` rather than the current year.
- Japanese Wikipedia added as a generation-level source, and `oem_fitment` added as a second, zero-cost source that covers the commercial vehicles ja.wikipedia does not.
- CRSP `Model number` chassis codes wired in as a matching input.
- A cleanup pass removed 7,185 rows whose years could not be true.

That cleanup is instructive: only 1,750 of the 7,185 deleted rows were in the originally-flagged "year before 1990" set. The rest looked plausible and were still wrong — for example an Audi "A3 SEDAN 30 TFSI" dated to 2006, when "30 TFSI" is a naming scheme Audi introduced after 2019. A year-floor filter alone would have missed them.

18.3 Coverage, Honestly Stated

Resolution rates track vehicle type rather than any particular make. Japanese passenger cars resolve well; Western and commercial vehicles much less so.

Group	Typical residue
Toyota	~49% unresolved — the best-covered make
Daihatsu, Honda, Volvo	~52-53%
Audi, Land Rover, Hino, Isuzu	91-97%
Chevrolet, Ford, MAN, Mini, Rolls-Royce, Scania, Tata	~100%

The practical consequence is that manual attention should be prioritised by `search_events` volume rather than by which nameplates look worst, because the gap is structural to the source rather than concentrated in a few fixable records.

18.4 Still Open

- Re-running enrichment to refill correct years for the nameplates the cleanup emptied. The cleanup only deletes; it never inserts, because there is no way to synthesise `engine_capacity` and `fuel` for a row that does not exist.
- Sweeping `web_battery_validation` rows orphaned by the deleted years.
- The manual nameplate pass for roughly 993 unresolved nameplates.
- A policy decision, still unmade: for nameplates no source can date, leave them without years (accurate, but they vanish from the year dropdown) or assign a conservative recent window (findable, but a guess).
- The `technology` column in `web_battery_validation` disagrees with `battery_code` on about 40% of rows. The matcher never reads that column — it parses `battery_code` instead — so this is a reporting artefact in exported spreadsheets rather than a recommendation defect. The fix is to populate the export from the resolved battery, or drop the column.

19. Glossary

Term	Meaning
Ah	Ampere-hours. Battery capacity; the primary sizing figure this system recommends
CCA	Cold Cranking Amps. Current the battery can deliver when cold; quoted here on the EN standard
AGM	Absorbent Glass Mat. Premium construction for heavy cycling, stop-start and high electrical load
EFB	Enhanced Flooded Battery. Mid-tier, designed for stop-start below AGM's duty
MF	Maintenance Free. Conventional sealed battery
SB (Flooded)	Standard flooded battery, the lowest tier in the priority order
NS / JIS	Japanese battery case and terminal standard. Used for Japanese, Korean and Chinese vehicles
DIN	European battery standard. Used for European, American and Indian vehicles
i-stop / stop-start	Engine cut at idle. Cycles the battery far harder, driving the EFB/AGM preference
JDM	Japanese Domestic Market. JDM trim names differ from export names, hence `model_aliases`

Term	Meaning
CRSP	The vehicle dataset this project is built from; the source of `vehicle_years`
Chassis code	Manufacturer type-approval code, e.g. `VJA300W`. Identifies a generation precisely where the model name does not
Nameplate	A model line across all generations — "Land Cruiser" as opposed to "Land Cruiser 250 VX"
Layer	One stage of the matching cascade; the first to produce an answer wins
Staging	The review table a pipeline writes to instead of the live table
Residue	Records a pipeline declined to resolve rather than guessing at

20. Appendix A — Environment Variables

Variable	Required	Default	Purpose
`DATABASE_URL`	Yes	—	Full-privilege `batteryfinder` role
`PUBLIC_DATABASE_URL`	Yes	—	Restricted `batteryfinder_public` role
`PUBLIC_DB_PASSWORD`	Migration only	—	Password used when the role is created
`ADMIN_COOKIE_SECURE`	No	`true`	`false` for local HTTP dev; also gates HSTS
`ADMIN_BOOTSTRAP_TOKEN`	Before first setup	—	Shared secret for `/admin/setup`
`ALLOWED_ORIGINS`	No	empty	Comma-separated CORS allowlist
`DB_POOL_SIZE`	No	`10`	Admin pool size
`DB_MAX_OVERFLOW`	No	`15`	Admin pool overflow
`PUBLIC_DB_POOL_SIZE`	No	`DB_POOL_SIZE`	Public pool size
`PUBLIC_DB_MAX_OVERFLOW`	No	`DB_MAX_OVERFLOW`	Public pool overflow
`DB_BACKUP_MODE`	No	`docker`	`docker` or `direct`
`DB_BACKUP_CONTAINER`	No	`battery-finder-postgres`	Container name in `docker` mode
`DB_BACKUP_USER`	No	from `DATABASE_URL`	Override the dump user
`DB_BACKUP_NAME`	No	from `DATABASE_URL`	Override the database name
`SES_FROM_EMAIL`	No	—	Verified SES sender; the feature no-ops if unset
`SES_REGION`	No	`us-east-1`	SES client region
`SEARXNG_URL`	No	—	SearXNG base URL; skipped if unset
`BRAVE_SEARCH_API_KEY`	No	—	Brave provider; skipped if unset
`BRAVE_MONTHLY_QUOTA`	No	`2000`	Brave call ceiling
`TAVILY_API_KEY`	No	—	Tavily provider; skipped if unset

Variable	Required	Default	Purpose
TAVILY_MONTHLY_QUOTA	No	1000	Tavily call ceiling

There is no MAINTENANCE_MODE variable. Maintenance is a row in app_settings (3.4).

21. Appendix B — Database Table Index

Table	Group	Written by
vehicle_years	Matcher source	CRSP pipeline commit, cleanup scripts
vehicle_years_exide	Matcher source (view)	Derived live from oem_fitment
battery_specs	Matcher source	Admin CRUD, Excel upload
model_aliases	Matcher source	Migrations, manual
dial_battery_inference	Matcher source	dial_battery_clean.py
web_battery_validation	Matcher source	Web-validation commit
oem_fitment	Matcher source	exide_fitment_clean.py
vehicles_raw	Pipeline	dataprep.py
vehicle_years_staging	Pipeline	enrich_years.py, expansion pipeline
vehicle_years_versions	Pipeline	Commit
vehicle_years_changelog	Pipeline	Commit
vehicle_years_unmatched	Pipeline	Enrichment run
vehicle_years_unverifiable	Pipeline	Quarantine scripts
web_battery_staging	Pipeline	web_battery_validate.py
web_battery_validation_versions	Pipeline	Commit
web_battery_validation_changelog	Pipeline	Commit
web_battery_unmatched	Pipeline	Web validation
pipeline_run_log	Pipeline	Any pipeline run
expansion_makes	Pipeline	Admin UI
fueleconomy_vehicles	Pipeline	Bulk CSV download
enrichment_cache_meta	Pipeline	Cache downloads
api_usage_quota	Pipeline	Provider calls
admin_users	Admin	Bootstrap, Admin Users page
admin_sessions	Admin	Login/logout
admin_account_audit_log	Admin	Account events
battery_audit_log	Admin	Battery mutations
admin_backup_log	Admin	Backup attempts
admin_stats	Telemetry	Read-counter flush
app_settings	Admin	Settings page
search_events	Telemetry	Every recommendation
user_feedback	User	Feedback modal
test_users	User	Test-user registration
test_user_sessions	User	Test-user login

22. Appendix C — Migration History

Applied in order by alembic upgrade head. The list doubles as a changelog of when each capability arrived.

Revision	Adds

Revision	Adds
20260505_932c18968f61	Initial schema
20260505_b3a9f2d1c8e4	Admin tables
20260511_a1b2c3d4e5f6	Test users and sessions
20260511_c7e1f9a2b3d5	user_feedback
20260511_d4e2f8a1b3c6	Feedback input/match columns
20260511_e5f1a2b3c4d6	recommended_battery on feedback
20260525_f6a1b2c3d4e5	origin, brand on battery_specs
20260526_a7b2c3d4e5f6	dial_battery_inference
20260526_b8c3d4e5f6a7	last_sale_date on inference
20260527_c9d4e5f6a7b8	web_battery_validation
20260529_a2b3c4d5e6f7	Vehicle fields on web validation
20260529_b3c4d5e6f7a8	Web-validation staging and versioning
20260529_d1e2f3a4b5c6	api_usage_quota
20260601_6259d46ad841	User tracking on versions
20260610_a1b2c3d4e5f6	30-day quota period
20260610_b2c3d4e5f6a7	vehicle_years staging and versioning
20260612_219dab65024d	app_settings
20260624_a1b2c3d4e5f6	vehicle_years_unmatched
20260624_b2c3d4e5f6a7	fueleconomy_vehicles
20260701_0369c7f9b5dc	search_events
20260701_1a2b3c4d5e6f	IP on search events
20260701_2b3c4d5e6f7a	Vehicle/battery fields on search events
20260701_3c4d5e6f7a8b	Performance indexes
20260704_d2e3f4a5b6c7	expansion_makes
20260708_e3f4a5b6c7d8	Login lockout on admin_users
20260709_f4a5b6c7d8e9	Review flag on web-battery staging
20260714_c1d2e3f4a5b6	oem_fitment and vehicle_years_exide
20260718_a3b4c5d6e7f8	input_type on search events
20260721_6e114cfe6168	Admin reset tokens and account audit log
20260721_c4d5e6f7a8b9	batteryfinder_public role and grants
20260722_3278f8c1b881	vehicle_years_exide converted to a view
20260728_4b7e9c2a1f83	admin_backup_log
20260812_fc5fac9ccee3	model_number on vehicle years
20260814_a7c3e91d5b42	vehicle_years_unverifiable
20260814_b8d4f02e6c17	Hino series aliases
20260815_c9e2a4b71f38	web_battery_unmatched

23. Appendix D — Repository Layout

```
.
├── backend/
│   ├── app.py                  public API, middleware, SPA serving, lifespan
│   ├── admin_router.py         every /api/admin/* route
│   ├── admin_auth.py           bcrypt, sessions, reset tokens
│   ├── matcher.py              the recommendation engine
│   ├── models.py               SQLAlchemy models
│   ├── db.py                   the two engines and their pools
│   ├── db_backup.py            pg_dump wrapper, docker and direct modes
│   ├── email_utils.py          SES password-reset email
│   ├── app_state.py            maintenance-mode flag with a 5s cache
│   ├── upload_pipeline.py      battery Excel validation and upsert
│   ├── alembic/versions/       migrations
│   ├── pipelines/              dataprep, enrich_years, ja_wikipedia_years,
│   │                           oem_fitment_years, web_battery_validate,
│   │                           exide_fitment_clean, dial_battery_clean,
│   │                           vehicle_coverage_expansion, model_name_utils
│   ├── scripts/                ~50 standalone remediation and report scripts
│   ├── tests/                  pytest suite + conftest fixtures
│   ├── cache/                  enrichment caches (safe to delete)
│   ├── data/                   source spreadsheets
│   ├── static/                 maintenance page, logo
│   └── requirements*.txt       runtime → pipeline → dev
├── frontend/
│   └── src/
│       ├── components/         VehicleFinderForm, AccuracyBar, modals, ui/
│       ├── pages/admin/        16 dashboard pages
│       ├── lib/                typed API wrappers, contexts, helpers
│       └── types/              shared TypeScript types
├── db-backup-script/           backup-db.ps1, restore-db.ps1
├── docker-compose.yml          local Postgres 15 on host port 5434
├── Jenkinsfile                 CI pipeline
├── .env                        local secrets — never committed
└── TECHNICAL_DOCUMENTATION.md  source of this document
```

The document you are reading is generated from that last file by `backend/scripts/md_to_docx.py`. Edit the markdown and regenerate; do not edit the Word file directly, or the next regeneration will discard the change.

End of document.